

External API v1.0.7

EHR Integration Documentation for secure access to NHS GP records

Documentation Version v 1.0.7

ORB API v1.0.7

ORB External API – Integration guide for EHR systems

Document version: 1.0.7 | Last updated: 21 October 2026.

Overview

ORB has been designed to support integration with other clinical systems, usually EHR systems.

In the typical case, clinicians in patient-facing organisations such as Clinics or Sporting Clubs will be using an EHR system to hold patient records, and they would like access to NHS records on those patients. Integrating ORB allows this to happen within the EHR.

This document defines the **ORB External API** for EHR integrations. The API has two main parts:

- Data Model Linkage - the API connects Organisations, Users and Patients from the EHR into ORB
- Data Access - the API allows the EHR system to show specific Patient data when requested by a specific User

Data Model

The API and ORB work with the following data model:

- Organisations - companies using the EHR which own/run clinics
- Users - People in the EHR linked to ORB via the integration (clinical and non-clinical)
- Patients - Individuals treated by the Clinicians

Note that an Organisation is usually not a clinic - it's the company that owns or runs clinics.

To integrate with ORB, EHR developers must use the API to create ORB data records corresponding to each Organisation, User and Patient - as this is necessary for ORB to work. The Organisation and User records are lightweight - they contain only the data sent by the EHR, and they aren't made available in the ORB UI. ORB will not update data held on these records, so there is no need to sync back from Orb, but we do have a ListUsers API to retrieve current users.

Patient records are used to invite the patient to register and share NHS data with the Organisations, and this data is accessible to the patient in the UI.

This API is **organisation-scoped**: all patient and user operations occur in the context of an Organisation.

This API uses external EHR IDs for Organisations, Users and Patients - internally there is a corresponding ORB ID but these are not published. This is to avoid the need for EHRs to store an additional ID.

The API assumes that EHR IDs always refer to the same data item, but otherwise tries not to makes assumptions. In particular, User records are assumed to be independent per Organisation - if a single user works at two organisations, this user has two records in ORB which are not linked.

Data Access

The second part of the API concerns access to Patient Data. The ORB API includes a JS Widget that the EHR developer should add to their Patient details page.

When a user wishes to open the widget to view patient data, the EHR must make a server-side request to obtain a short-lived access token linked to that user and that patient. This is then passed to the widget.

Table of contents

- Authentication — API key, base URL, API keys
- Conventions — JSON, dates, external IDs
- Common errors — HTTP status codes, errorCode values
- Organisations — Create, Update (including suspend/unsuspend), Delete, Generate API key, Get, List, contract status, contract access token, branding
- Users — Create, Update, List, Delete (isClinician, isLocum, authorisedSignatory)
- Patients — List, Update, Connect by Email, Connect by Link, Get connection status, Get granted permissions, Remove connection
- Patient Access — Request access token, (widget embed guide);
- Stats — Widget T&C signed counts; NHS records viewed per organisation / user
- Terms and Conditions — Clinician widget T&C; Organisation contract
- Support and API access — API keys, support, rate limits

Authentication

All API communication must use **HTTPS** (TLS 1.2 or higher recommended). Do not send API keys or patient data over unencrypted connections.

Each request is authenticated with one API key:

- The GovBody API key can be used on every endpoint (existing integrations keep using this header unchanged):

```
X-API-KEY: <your-govbody-api-key>
```

- An Organisation API key can be used only on requests made for that Organisation:

```
X-ORG-API-KEY: <organisation-api-key>
```

Which endpoints need which key

Endpoint	**Key**
Create Organisation — POST /organisations/{extOrganisationId}	X-API-KEY
Delete Organisation — DELETE /organisations/{extOrganisationId}	X-API-KEY
Generate Organisation API Key — POST /organisations/{extOrganisationId}/api-key	X-API-KEY
List Organisations — GET /organisations	X-API-KEY
Stats — GET /stats/... without extOrganizationKey	X-API-KEY
Stats — GET /stats/... with extOrganizationKey	X-ORG-API-KEY or X-API-KEY
Every other endpoint under /organisations/{extOrganisationId} (Organisations, Users, Patients, Patient Access, contract)X-ORG-API-KEY or X-API-KEY	X-ORG-API-KEY or X-API-KEY

Endpoints marked X-API-KEY are GovBody-level: an Organisation API key cannot be used on them (sending only X-ORG-API-KEY returns **401**). Endpoints marked "X-ORG-API-KEY or X-API-KEY" accept either that Organisation's API key or its GovBody's API key. When X-ORG-API-KEY is sent it is the key that is checked and X-API-KEY is ignored; otherwise X-API-KEY is checked.

The Organisation API key must belong to the Organisation identified by extOrganisationId (or extOrganizationKey on Stats). A key issued for Organisation A cannot be used for Organisation B.

When X-API-KEY is checked:

- Absent or blank → HTTP **401 Unauthorized** with an empty body.
- Not registered for a GovBody → HTTP **404** ClientNotFound.
- Key expired → HTTP **403** ApiKeyExpired.
- EHR API disabled for the GovBody → HTTP **403** ApiDisabled.
- On Organisation endpoints, the Organisation does not exist in the GovBody → HTTP **404** OrgNotFound.

When X-ORG-API-KEY is checked:

- Absent or blank → HTTP **401 Unauthorized** with an empty body.
- Not a valid Organisation API key, or the key of a different Organisation → HTTP **403** OrgApiKeyInvalid.
- Valid key, but the requested Organisation does not exist in the key's GovBody → HTTP **404** OrgNotFound.
- The Organisation's GovBody API key has expired → HTTP **403** ApiKeyExpired.
- EHR API disabled for the Organisation's GovBody → HTTP **403** ApiDisabled.
- Organisation API key expired → HTTP **403** OrgApiKeyExpired.
- Organisation API key disabled by ORB → HTTP **403** OrgApiDisabled.

Widget and contract access tokens are tied to the API key used to request them (the Organisation API key or the GovBody API key). A token stops working immediately (HTTP **401**, or **403** with the codes above) when:

- that key is regenerated;
- for tokens requested with the Organisation API key, that key is disabled or expires;
- the GovBody's API key expires or the EHR API is disabled for the GovBody (all tokens).

Request a new token with a current key.

Base URL

The ORB API is available at the following base URL:

- https://api-test-app.orbforhealth.com/v1

Access to base URLs will be provided when your API key is issued.

Route prefixes (implementation):

- **Organisation** and **User** endpoints: v1/organisations/{extOrganisationId}
- **Patient** endpoints: v1/organisations/{extOrganisationId}/patients

For example, to create an organisation in the test environment, you would make a POST request to:

```
https://api-test-app.orbforhealth.com/v1/organisations/{extOrganisationId}
```

API Keys

There are two types of API key. Both are issued by ORB.

GovBody API key (X-API-KEY)

- Each GovBody API Key is linked to **ONLY one External EHR**
    - Within ORB this is called a Governing Body (GovBody)
- A GovBody may contain multiple Organisations
- Can be used on every endpoint, including requests made for any of its Organisations
- Must not be shared with the Organisations
- Existing integrations that send only X-API-KEY continue to work; Organisation API keys are optional

Organisation API key (X-ORG-API-KEY)

- Each Organisation API Key is linked to **ONLY one Organisation** within the GovBody
- Can be used on every request made for that Organisation (see the table above), but not on GovBody-level endpoints
- Not created by **Create Organisation**. The GovBody can generate an Organisation's first key with Generate Organisation API Key, which returns the key once; otherwise ORB generates it and shares it separately. Only ORB can regenerate, disable or re-enable an Organisation API key
- Optional: an Organisation with no Organisation API key (or with a disabled or expired one) can still be used through the GovBody API key
- Regenerating, disabling or re-enabling the key of one Organisation has no effect on any other Organisation
- Organisation API keys only work while the GovBody's API key has not expired and the EHR API is enabled for the GovBody. Regenerating the GovBody API key does not affect Organisation API keys

---

Conventions

- All requests and responses use JSON; requests with a body should use Content-Type: application/json
- Dates are ISO-8601 formatted
- External IDs (extOrganisationId, extUserId, extPatientId) are provided by the EHR and treated as stable
- Published path parameter names use those `*Id` forms. ASP.NET route templates use `extOrganizationKey`, `extUserKey`, and `extPatientKey` for the same path segments; JSON request/response fields use the `*Id` names. Stats query parameter `extOrganizationKey` is the same value as `extOrganisationId`
- ORB does **not** expose internal ORB IDs - so EHR does not need to store them
- Deleted records are retained for legal purposes, but are not re-used and are inaccessible

Key terms

Term	Meaning
GovBody	Governing Body; the EHR (or partner) linked to one API key. A GovBody contains many Organisations.
External ID	extOrganisationId, extUserId, or extPatientId— the identifier from the EHR. ORB does not publish its internal IDs.
ConnectionStatus	Patient's NHS login/connection state (e.g. InviteNotSent, InviteSent, Connected, DataMismatch, Declined). See Patients section.
DataAccessStatus	Whether the patient has been asked to grant access and whether they have granted or declined (RequestNotSent, RequestSent, Reviewed, Declined).

Common Errors

The following HTTP status codes may be returned by any endpoint in addition to endpoint-specific errors:

Status	Meaning
401	Missing API key (neither X-ORG-API-KEY nor X-API-KEY on Organisation endpoints, no X-API-KEY on GovBody-level endpoints) — typically empty body (see Authentication). Unknown GovBody key is usually **404** ClientNotFound; expired GovBody key is **403** ApiKeyExpired; invalid, disabled or expired Organisation key is **403** OrgApiKeyInvalid / OrgApiDisabled / OrgApiKeyExpired.
500	Internal server error - an unexpected error occurred on the server
503	Service unavailable - the service is temporarily unavailable, please retry later

For 503, use exponential backoff when retrying.

For other 4xx and 5xx responses, the body may include a JSON object describing the error.

For **400 Bad Request** when the request cannot be parsed or accepted—for example malformed JSON, a required body field missing, a query or path value in the wrong form (such as offset=0sd when an integer is expected), a value outside the permitted set (such as "sex": "Female1" when only defined values are accepted), or a property not defined for that operation (such as an unknown field "newField" in a **PATCH** or **POST** request body)—and no more specific ORB **errorCode** applies, the response always includes **errorCode InvalidRequestData** and a single **errorMessage**.

The response contains **only** these two members.

errorMessageis intended for display. It is either a fixed general sentence or—commonly—a short line naming one query parameter and the rejected value when only that parameter is at fault (see **InvalidRequestData** below). Wording may change in later API versions; use **errorCode**for programmatic handling and **do not** parse **errorMessage**for business logic.

Property	Type	Description
errorMessage	string	Human-readable error message. Example: "No organisation found for the given ID".
errorCode	string?	Optional. Present when the exception is a known ORB API exception; see values below.

Example response body:

```
{
  "errorMessage": " No organisation found for the
  given ID",
  "errorCode": "OrgNotFound"
}
```

Possible errorCode values:

- **ClientNotFound** - The caller client is not registered in ORB or the corresponding governing body record is missing for some reason. Cannot validate API key nor allow further operations from this caller.
- **OrgNotFound** - There is no existing organisation corresponding to the provided id.
- **OrgLinkNotFound** - User or patient is not linked to the organisation corresponding to the provided id.
- **UserNotFound** - There is no existing user corresponding to the provided id.
- **PatientNotFound** - There is no existing patient corresponding to the provided id.
- **InvalidRequestData** — Returned when the request body, query string, or path cannot be parsed or validated successfully, and no more specific ORB **errorCode**applies. The response body is always the compact JSON object { "errorCode", "errorMessage" }described under **Common Errors** above. errorMessage is assigned as follows:
    - **General message** — Used when more than one validation issue is reported for the same request, and in typical cases where the problem lies in the **JSON request body** only—including a value outside a permitted enumeration (for example "sex": "Female1" when only defined values are accepted), or a property not defined for that operation (for example an unknown or misspelled field name in a **PATCH** or **POST** body). Request bodies must contain **only** properties listed for that endpoint; extra properties are rejected with **400**, not ignored. In these cases **errorMessage** is a single standard sentence; clients must not assume a field-by-field breakdown in the message text.

      ```
      {
        "errorCode": "InvalidRequestData",
        "errorMessage": "One or more fields contain invalid values. Please
      verify the input data."
      }
      ```

    - **Per-parameter message (query)** — Typically used when a **single** query (or equivalent) parameter does not match its expected type; **errorMessage**may then identify the parameter and the supplied value:

      ```
      {
        "errorCode": "InvalidRequestData",
        "errorMessage": "The value '0sd' is not valid for Offset."
      }
      ```

  Other isolated query-parameter errors may follow the same pattern. The exact wording of **errorMessage** is not guaranteed across API versions; use it for display only and base integration logic on **errorCode**.

- **UnsupportedMediaType** - Returned on Set Organisation Branding as HTTP 415 when the upload is not an allowed image type (PNG, JPEG, JPG, or SVG), the file content does not match its declared type, or the request is not multipart/form-data. Same compact { "errorCode", "errorMessage" } body shape as other errors.

- **InvalidProperty** - Some request body field holds an invalid value (used when the API returns a specific semantic validation outcome rather than the generic **InvalidRequestData** body above).

- **InvalidParameter** - Some request parameter holds an invalid value.

- **IdNotAvailable** - The id provided is already in use by another **active or suspended** entity of the same type. For organisations, this includes a suspended organisation (reactivate with Update Organisation; do not Create again). An archived (deleted) organisation does not keep the extOrganisationId; Create may reuse it for a **new** organisation.

- **NameNotAvailable** - The name provided is already in use by another entity of the same type. For example, client tried to create a new organisation using the same name of an existing one.

- **EmailNotAvailable** - The email provided is already in use by another entity of the same type. For example, client tried to create a new user using the same email of an existing one.
- **PatientInvalidStatus** - The operation requested cannot be performed given the current status of the patient (for example the patient is not **Connected** when requesting an access token).
- **ResendLimitExceeded** - The client has exceeded the patient connection rate limit for invitation or data-access connect calls (per patient / per organisation / rolling 24 hours). See **Rate limits** under Patients. Returned **as HTTP 429**.
- **PatientDetailsMismatch** - Request demographics conflict with the existing ORB patient record (HTTP **409**). Returned when:
    - **Connect by Email** or **Connect by Link** — email already exists but request DOB and/or surname do not match (same **409** / compact { errorCode, errorMessage } on both); or
    - **Update Patient** — patient has NHS Login and firstName / lastName / dateOfBirth on the request do not match NHS-controlled values (omitted fields count as mismatch — include matching values when updating other demographics). Distinct from **422** connectionStatus **DataMismatch** (NHS→ORB after NHS login; body uses dobMismatch / surnameMismatch, not errorCode).
- **PatientAccountNotActivated** - **Connect by Email** or **Connect by Link** for an existing ORB patient (matched by email) who has not activated their ORB account and has no NHS Login (HTTP **409**). The NHS Login invitation cannot be sent until the patient activates their ORB account. The patient is not linked to the organisation.
- **NonClinicianAccess** - A patient access token was requested for a user with isClinician: false (only clinical users may request access tokens).
- **OrgIsSuspended** - The organisation is suspended; protected operations such as contract-access-token and patient access-token are blocked (**403**).
- **NhsModuleDisabled** - The organisation NHS module is not enabled; patient access-token issue is blocked (**403**). (Widget-side NHS-module unavailable UI may still apply separately.)
- **ApiDisabled** - The EHR API is disabled for this Governing Body / API key client (**403**).
- **ApiKeyExpired** - The GovBody API key has expired (**403**).
- **OrgApiKeyInvalid** - X-ORG-API-KEY is not a valid Organisation API key, or it belongs to a different

Organisation than the one requested (**403**).

- **OrgApiDisabled** - The Organisation API key has been disabled by ORB (**403**).
- **OrgApiKeyExpired** - The Organisation API key has expired (**403**).
- **OrgApiKeyAlreadyExists** - **Generate Organisation API Key** was called for an Organisation that already has an API key (**409**).
- **OrgAlreadyArchived** - Kept in the errorCode list for compatibility. A second Delete of an already-deleted organisation, and other organisation-scoped calls against an archived organisation, return **404** (OrgNotFound). Archived organisations are not visible on the API.
- **OrganisationContractNotSigned** - The organisation has not completed ORB organisation contract signing. Protected EHR API and widget operations for that organisation remain blocked until the contract is signed. See Organisation contract (clinic).
- **PatientDataAccessLimited** - No longer returned. Limited patient or GP data access (patientDataAccessLimited / gpDataAccessLimited) does not block access-token or the NHS Records widget; the widget opens for any **Connected** patient and each restricted data type shows a limited-data message instead of records. The code is kept in the errorCode list for compatibility only.
- **GenericError** - The current error does not contain relevant information for the client. Often, this is just an internal logic error of the server, and does not require actions on the client side.

For unexpected or non-API exceptions, errorCodemay be omitted. Clients can use errorMessagefor display and optionally use errorCodefor programmatic handling.

Organisations

Each EHR organisation must complete the Organisation contract before most Users, Patients, and Widget operations are available..

Create Organisation

POST /organisations/{extOrganisationId}

Creates an Organisation in ORB under the GovBody associated with the API Key. Authenticated with the GovBody X-API-KEY only. Creation is allowed before the organisation contract is signed (required for onboarding). An Organisation API key is **not** created here — use Generate Organisation API Key afterwards if the Organisation should have its own X-ORG-API-KEY.

On create, ORB sets default NHS linking welcome text used on the patient-facing EHR linking page (see Set Organisation Branding):

- Welcome title: Welcome to ORB
- Welcome subtitle: Please login/register with your NHS account to continue.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Request Body

```
{
  "organisationName": "string",
  "address1": "string",
  "address2": "string",
  "address3": "string",
  "address4": "string",
  "postcode": "string",
  "phoneNumber": "string",
  "cqcRegistrationNumber": "string",
  "researchOptOut": boolean
}
```

Request Body Fields

Field	Type	Required	Description
organisationName	string	Yes	Unique Organisation name (case-insensitive)
address1	string	No	First line of address. May be omitted, null or empty.
address2	string	No	Second line of address. May be omitted, null or empty.
address3	string	No	Third line of address. May be omitted, null or empty.
address4	string	No	Fourth line of address. May be omitted, null or empty.
postcode	string	No	Postcode. May be omitted, null or empty.
phoneNumber	string	No	Organisation phone number. May be omitted or empty.
cqcRegistrationNumber	string	No	CQC registration number. May be omitted or empty.
researchOptOut	boolean	No	Research opt-out flag (defaults to false/off)

Notes:

- extOrganisationId must be unique among **active and suspended** organisations within the GovBody. If it belongs to an **archived** (deleted) organisation, Create succeeds and creates a **new** organisation. The archived organisation is not reactivated; its patients, users, EHR mappings, and NHS/clinical data stay with it and are not associated with the new organisation. Subsequent API calls using that extOrganisationId resolve to the new organisation.
- If the ID belongs to an **active** organisation, Create returns **409** IdNotAvailable.
- If the ID belongs to a **suspended** organisation, Create also returns **409** IdNotAvailable. Reactivate with Update Organisation (suspended: false); do not Create again. Suspend/unsuspend behaviour is unchanged.
- organisationName must be unique among **non-archived** organisations within the GovBody (case-insensitive). A name used only by an archived organisation may be reused.
- The address (address1, address2, address3, address4, postcode) is optional. An organisation can be created with organisationName only and the address added later through Update Organisation.
- phoneNumber is optional. If omitted or empty, the organisation is created without a phone number.
- cqcRegistrationNumber is optional and is trimmed before storing. If omitted, empty or whitespace-only, the organisation is created without a CQC registration number.

Responses

Status	Meaning
201	Organisation created
400	Creation failed due to invalid request or validation error
403	EHR API disabled (ApiDisabled) or API key expired (ApiKeyExpired)
404	No external client found for the provided API key
409	Organisation already exists with the same extOrganisationId (IdNotAvailable — active or suspended, not archived) or organisationName (NameNotAvailable)

Update Organisation

PATCH /organisations/{extOrganisationId}

Updates organisation details or suspends / unsuspends the organisation. Requires the organisation contract to be signed.

- If an organisation is suspended it is not considered for billing, and no Users can access data via API. Patients are unaffected - Patients can still login/register with the Organisation via the ORB UI.
- Organisations cannot be suspended indefinitely. When suspending, the caller may specify autoDeleteDays to set when automatic deletion happens. If not specified this happens in 180 days.
- Organisations can be unsuspended using this feature to restore access for Users accessing data via API, and will again be considered for billing.
- **Clearing**
  fields: address1, address2, address3, address4, postcode, phoneNumber and cqcRegistrationNumber distinguish "not supplied" from "supplied". Omit the field to leave the stored value unchanged; send null to clear it. Any other value is stored as sent, including an empty or whitespace-only string. The exception is cqcRegistrationNumber, which is trimmed before storing and cleared when empty or whitespace-only. organisationName ignores empty or whitespace-only values, so it cannot be cleared through this endpoint.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Request Body

```
{
  "organisationName": "string",
  "address1": "string",
  "address2": "string",
  "address3": "string",
  "address4": "string",
  "postcode": "string",
  "phoneNumber": "string",
  "cqcRegistrationNumber": "string",
  "researchOptOut": boolean,
  "suspended": boolean,
  "autoDeleteDays": number
}
```

Request Body Fields

Field	Type	Required	Description
organisationName	string	No	Unique Organisation name (case-insensitive)
address1	string	No	First line of address. Send null to clear; omit to leave unchanged
address2	string	No	Second line of address. Send null to clear; omit to leave unchanged
address3	string	No	Third line of address. Send null to clear; omit to leave unchanged
address4	string	No	Fourth line of address. Send null to clear; omit to leave unchanged
postcode	string	No	Postcode. Send null to clear; omit to leave unchanged
phoneNumber	string?	No	Phone number. Send null to clear the stored number; omit to leave unchanged
cqcRegistrationNumber	string?	No	CQC registration number (trimmed). Send null or an empty string to clear the stored number; omit to leave unchanged
researchOptOut	boolean	No	Research opt-out flag
suspended	boolean	No	Suspended flag
autoDeleteDays	number	No	Auto-delete after suspension in days (max 180, default 180)

Responses

Status	Meaning
200	Organisation updated
400	Update failed due to invalid request or validation error
403	Organisation contract not signed (`OrganisationContractNotSigned`)
404	Organisation corresponding to given id or Governing Body corresponding to given API key not found
409	Organisation Name already exists

Delete Organisation

DELETE /organisations/{extOrganisationId}

Delete the organisation and all associated users. Authenticated with the GovBody X-API-KEY (an Organisation cannot delete itself); the Organisation API key is removed when the organisation is deleted. Deletion does **not** require the organisation contract to be signed, so an organisation created by mistake can be removed before signing. This should be used if an organisation asks to turn OFF the integration permanently or if it leaves the EHR system.

Once deleted, the organisation is **archived** (not hard-removed):

- Organisation-scoped API calls using this extOrganisationId return **404** until the ID is used again on Create.
- The same extOrganisationId may be reused on Create Organisation. That creates a **new** organisation; it does not unarchive the previous one. Patients, users, EHR mappings, and NHS/clinical data remain on the archived organisation and are not transferred.
- Only one **active** organisation may use the extOrganisationId at a time. A **suspended** organisation still holds the ID until it is unsuspended or later archived — Create with that ID then returns **409** IdNotAvailable.
- If a patient has no other organisations linked to their profile, they will no longer be able to login.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Responses

Status	Meaning
200	Organisation deleted
400	Deletion failed due to invalid request or validation error
403	EHR API disabled (ApiDisabled)
404	Organisation not found (including if it was already deleted / archived)

A successful response (200) returns no response body.

Generate Organisation API Key

POST /organisations/{extOrganisationId}/api-key

Generates the Organisation API key (X-ORG-API-KEY) for an Organisation that does not have one yet, and returns it. Authenticated with the GovBody X-API-KEY only (an Organisation cannot request its own key). Does not require the organisation contract to be signed.
The full key is returned only once, in this response; ORB stores only a hash of it and cannot return it again. Store it securely and pass it to the Organisation. If the Organisation already has a key (enabled, disabled or expired), no new key is generated and the API returns 409 OrgApiKeyAlreadyExists; to replace or re-enable an existing key, contact ORB support.
The new key is enabled immediately and expires after the same lifetime as the GovBody API key (apiKeyExpiresAt; null when keys do not expire).

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Request Body

```
{
  "extOrganisationId": "string",
  "apiKey": "string",
  "apiKeyExpiresAt": "2027-10-07T14:53:00+00:00"
}
```

Response Body Fields

Field	Type	Description
extOrganisationId	string	External organisation ID (EHR)
apiKey	string	The Organisation API key, sent as X-ORG-API-KEY. Returned only in this response
apiKeyExpiresAt	string (ISO-8601) or null	When the key expires; null if it does not expire

Responses

Status	Meaning
201	Key generated and returned
401	X-API-KEY missing (the Organisation API key is not accepted here)
403	GovBody API key expired (ApiKeyExpired) or EHR API disabled (ApiDisabled)
404	GovBody API key unknown (ClientNotFound), or the Organisation does not exist in the GovBody (OrgNotFound)
409	The Organisation already has an API key (OrgApiKeyAlreadyExists)
500	Unexpected server error

Get Organisation

GET /organisations/{extOrganisationId}

Returns the organisation details for the given external organisation ID. When X-ORG-API-KEY is used it must belong to that organisation.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Response Body

A successful response (200) returns the organisation summary:

```
{
  "extOrganisationId": "string",
  "organisationName": "string",
  "suspended": false,
  "autoDeleteDate": "string"
}
```

Response Body Fields

Field	Type	Description
extOrganisationId	string	External organisation ID (EHR)
organisationName	string	Organisation name
suspended	boolean	Suspension status
autoDeleteDate	string?	Auto-delete date in YYYY-MM-DD format when suspended; null if not set

Note: autoDeleteDate is only populated when suspended = true.

Responses

Status	Meaning
200	Organisation exists in Governing Body
400	Bad request
404	Organisation not found

List Organisations

GET /organisations

Returns a list of organisations under the Governing Body linked to the API key. Authenticated with the GovBody X-API-KEY only (an Organisation API key cannot list organisations). Includes suspension status and auto-delete date when suspended. Filtering by suspension status is optional.

Query Parameters

Name	Type	Required	Default	Description
suspended	boolean	No	-	Filter by suspension status. Omit to return all results

Response Body

```
[
  {
    "extOrganisationId": "string",
    "organisationName": "string",
    "suspended": boolean,
    "autoDeleteDate": "string"
  }
]
```

Response Body Fields

Field	Type	Description
[].extOrganisationId	string	External organisation ID (EHR)
[].organisationName	string	Organisation name
[].suspended	boolean	Suspension status
[].autoDeleteDate	string	Auto-delete date in YYYY-MM-DD format when suspended; null if not set

Note: autoDeleteDate is only populated when suspended = true.

Example Requests

Get all organisations:

```
GET /organisations
```

Get only suspended organisations:

```
GET /organisations?suspended=true
```

Get only active (not suspended) organisations:

```
GET /organisations?suspended=false
```

Responses

Status	Meaning
200	OK
404	Governing Body corresponding to given API key not found

Get Organisation Contract Status

GET /organisations/{extOrganisationId}/contract-status

Returns whether the organisation has signed the ORB organisation contract and when. The host uses this to decide whether to show the contract signing iframe and to verify status after signing. Available before the contract is signed (not gated).

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Response Body

When not signed:

```
{
  "extOrganisationId": "org-123",
  "contractSigned": false,
  "contractSignedAt": null
}
```

When signed:

```
{
  "extOrganisationId": "org-123",
  "contractSigned": true,
  "contractSignedAt": "2026-05-
22T10:30:00Z"
}
```

Response Body Fields

Field	Type	Description
extOrganisationId	string	External organisation ID (EHR); same value as in the path
contractSigned	boolean	**true** after successful organisation-contract signing; **false** until then
contractSignedAt	string | null	UTC ISO-8601 timestamp of signing; present only when **contractSigned** is **true**, otherwise **null**

Responses

Status	Meaning
200	OK
401	Missing API key (empty body). Unknown key typically returns 404 ClientNotFound
403	EHR API disabled for this client
404	Organisation not found for this API key / client
500	Unexpected server error

Request Contract Access Token

POST /organisations/{extOrganisationId}/contract-access-token

Generates a short-lived organisation-scoped token used to open the ORB organisation-contract signing iframe. Available **before** the contract is signed (not gated). The token identifies the API-key client and external organisation only (no patient or user claim).

The host uses either the Organisation's API key (X-ORG-API-KEY) or the GovBody API key (X-API-KEY), and the same extOrganisationId that was passed when the organisation was created. When the Organisation API key is used, ORB validates that it belongs to that organisation before issuing the token. The token is tied to the key used to request it (see Authentication).

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR). When X-ORG-API-KEY is used, must be the Organisation that key belongs to; scopes the contract-signing iframe to that organisation

Request Body

None.

Response Body

```
{
  "accessToken": "string",
  "expiresIn": 900
}
```

Response Body Fields

Field	Type	Description
accessToken	string	Short-lived JWT for the organisation-contract signing iframe only (not the patient records widget). Pass into the iframe via SET_TOKEN / openOrbWidget (see Widget Integration Guide)
expiresIn	integer	Seconds until the token expires from issue time (configured on ORB; typically 900 = 15 minutes). Generate a new token if the iframe session outlives this value

JWT Token Claims

The contract JWT contains:

- clientScopeId - Internal API-key client identifier
- extOrganisationId - The organisation ID
- tokenScope - Always organisation-contract (distinguishes this token from a patient-records widget token)
- iat / exp / aud / iss - As for other ORB widget JWTs

There is no extUserId or extPatientId claim.

Responses

Status	Meaning
200	Token issued
401	Missing API key (empty body). Unknown key typically returns 404 ClientNotFound
403	Organisation suspended, or EHR API disabled for this client
404	Organisation not found for this API key / client
500	Unexpected server error

Embedding, postMessage, and the in-iframe signing UI are documented under Organisation contract (clinic) and in the ORB Widget Integration Guide.

Set Organisation Branding

POST /organisations/{extOrganisationId}/branding

Updates the organisation logo and optional welcome title/subtitle shown on the patient-facing NHS linking page (the page patients see when the EHR uses Connect Patient by Email or Connect Patient by Link).

Requires the organisation contract to be signed (403 OrganisationContractNotSigned otherwise).

Request is multipart/form-data (not JSON). A successful call returns 204 with no body.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Request Body

Send as multipart/form-data (this endpoint accepts a file upload, so JSON body is not used).

Field	Type	Required	Description
overwriteLogo	boolean	No	Set to **true** to replace the logo (**file**) or clear it (no **file**). If omitted or **false**, the current logo is unchanged.
file	binary	No	Logo image — PNG, JPEG, JPG or SVG, max 1 MB. Uploading a new file replaces the previous logo.
patientNHSActivationWelcomeTitle	string	No	Welcome title on the NHS linking page. Updated only when this field is included.
patientNHSActivationWelcomeSubtitle	string	No	Welcome subtitle on the NHS linking page. Updated only when this field is included.

You may update welcome text without changing the logo (omit overwriteLogo, or set it to false).

You may change the logo without sending welcome fields.

Patient experience

If welcome text has not been customised, patients see the create-organisation defaults (Welcome to ORB / Please login/register with your NHS account to continue.).

On the linking page the patient sees:

- the organisation logo when one is uploaded, otherwise ORB's default branding mark;
- the welcome title and subtitle;
- an **NHS Login** button only with the self register option

Responses

Status	Meaning
204	Branding updated (no response body)
400	Invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled
404	Organisation or Governing Body not found
415	Unsupported media type (**UnsupportedMediaType**) — file not PNG/JPEG/JPG/SVG, content mismatch, or not multipart

Users

Users represent Clinicians who are granted access via the integration. They do not have general login access to the ORB UI.

EHR systems use the **isClinician** flag to distinguish clinical users from non-clinical users (for example administrative staff).

Each user record includes three boolean flags:

- **isClinician** — **true** if the user is a clinical user who may access NHS patient data via the integration (widget / access token); **false** for non-clinical users (for example administrative staff).
- **isLocum** — **true** if the user is a temporary locum; **false** if a permanent employee.
- **authorisedSignatory** — **true** if this user is an authorised signatory for the organisational contract.

All three flags are required when creating a user; any of them may be supplied on update.

User create, update, list, and delete require the organisation contract to be signed («403» **OrganisationContractNotSigned** otherwise).

Create User

POST /organisations/{extOrganisationId}/users/{extUserId}

Creates an ORB user within an ORB organisation, linked to the corresponding external User ID.

This is used to grant a user access to the integration. Set isClinician to **true** for clinical users and **false** for non-clinical users. Only users with isClinician: true may request patient access tokens (see [Request Access Token](#request-access-token)).

- For Users we assume the external IDs are unique within an Organisation, and do not change.
- We do not attempt to link or merge users – nor do we identify duplicates based on personal attributes (e.g. FirstName, LastName, ProfessionalRegNumber).
- If the same clinician exists in multiple organisations in the EHR, a separate ORB user must be created for each organisation, even if in EHR they are shared.

The number of Users in existence during a month may be used in billing. The system logs user creation and deletion and this log is available for billing.

Path Parameters

Name	Description
extOrganisationId	External Organisation ID (EHR)
extUserId	External User ID (EHR)

Request Body

```
{
  "firstName": "string",
  "lastName": "string",
  "professionalRegNumber": "string",
  "emailAddress": "string",
  "isClinician": true,
  "isLocum": false,
  "authorisedSignatory": false
}
```

Request Body Fields

Field	Type	Required	Description
firstName	string	Yes	User's first name
lastName	string	Yes	User's last name
professionalRegNumber	string	No	Professional registration number. May be omitted or empty (e.g. clinicians without a registration number).
emailAddress	string	No	User's email address
isClinician	boolean	Yes	**true** if the user is a clinical user; **false** for non-clinical users (e.g. administrative)
isLocum	boolean	Yes	if the user is a temporary locum; false if a permanent employee
authorisedSignatory	boolean	Yes	**true** if this user is an authorised signatory for the organisational contract

Notes:

- professionalRegNumber is optional on create. Omit or leave blank when the clinician has no professional registration number.

Responses

Status	Meaning
201	User created
400	Creation failed due to invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Organisation not found
409	User already exists in this organisation with the same extUserId (IdNotAvailable), or email already in use (EmailNotAvailable)

Update User

PATCH /organisations/{extOrganisationId}/users/{extUserId}

Updates one or more attributes of an existing user within an organisation.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extUserId	External user ID (EHR)

Request Body

```
{
  "firstName": "string",
  "lastName": "string",
  "professionalRegNumber": "string",
  "emailAddress": "string",
  "isClinician": true,
  "isLocum": false,
  "authorisedSignatory": false
}
```

Request Body Fields

Field	Type	Required	Description
firstName	string	No	User's first name
lastName	string	No	User's last name
professionalRegNumber	string	No	Professional registration number
emailAddress	string	No	User's email address
isClinician	boolean	No	If supplied, updates whether the user is a clinical user (true) or non-clinical (false)
isLocum	boolean	No	If supplied, updates whether the user is a locum (true) or permanent (false)
authorisedSignatory	boolean	No	If supplied, updates authorised signatory flag for the organisational contract

Responses

Status	Meaning
200	User updated
400	Invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	User or organisation not found

List Users

GET /organisations/{extOrganisationId}/users

Returns users for the organisation (regardless of whether the organisation is currently suspended). Pagination is optional - if no pagination parameters are provided, all users are returned as an array. If pagination parameters are provided, a paginated response with metadata is returned.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)

Query Parameters

Name	Type	Required	Default	Description
limit	integer	No	-	Maximum number of users to return (1-1000). If omitted, all users are returned
offset	integer	No	0	Number of users to skip before returning results. Only used when limit is provided

Response Body (No Pagination)

When no pagination parameters are provided, the response is a simple array:


```
[
  {
    "extUserId": "string",
    "firstName": "string",
    "lastName": "string",
    "professionalRegNumber": "string",
    "emailAddress": "string",
   "isClinician": true,
    "isLocum": false,
    "authorisedSignatory": false
  }
]
```

Response Body (With Pagination)

When limit is provided, the response includes pagination metadata:


```
{
  "users": [
    {
      "extUserId": "string",
      "firstName": "string",
      "lastName": "string",
      "professionalRegNumber": "string",
      "emailAddress": "string",
      "isClinician": true,
      "isLocum": false,
      "authorisedSignatory": false
    }
  ],
  "pagination": {
    "total": 150,
    "limit": 100,
    "offset": 0,
    "hasMore": true
  }
}
```


Response Body Fields

When pagination is not used (array response):

Field	Type	Description
[].extUserId	string	External user ID (EHR)
[].firstName	string	User's first name
[].lastName	string	User's last name
[].professionalRegNumber	string	Professional registration number (may be null or empty)
[].emailAddress	string	User's email address
[].isClinician	boolean	true if clinical user; false if non-clinical
[].isLocum	boolean	True if locum; false if permanent employee
[].authorisedSignatory	boolean	True if authorised signatory for the organisational contract

When pagination is used (object response):

Field	Type	Description
users	array	Array of user objects
users[].extUserId	string	External user ID (EHR)
users[].firstName	string	User's first name
users[].lastName	string	User's last name
users[].professionalRegNumber	string	Professional registration number
users[].emailAddress	string	User's email address
users[].isClinician	boolean	**true** if clinical user; **false** if non-clinical
users[].isLocum	boolean	**true** if locum; false if permanent employee
users[].authorisedSignatory	boolean	**true** if authorised signatory for the organisational contract
pagination	object	Pagination metadata
pagination.total	integer	Total number of users in the organisation
pagination.limit	integer	Number of users requested per page
pagination.offset	integer	Number of users skipped
pagination.hasMore	boolean	Whether there are more users available

Example Requests

Get all users (no pagination):

```
GET /organisations/ORG123/users
```

Get first 100 users (with pagination):

```
GET /organisations/ORG123/users?limit=100&offset=0
```

Get next 50 users:

```
GET /organisations/ORG123/users?limit=50&offset=100
```

Responses

Status	Meaning
200	OK
400	Invalid pagination parameters (limit > 1000, limit < 1, or offset < 0)
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Organisation not found

Delete User

DELETE /organisations/{extOrganisationId}/users/{extUserId}

Deletes the specified user from the organisation. After deletion, the user will no longer be able to access the integration for this organisation.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extUserId	External user ID (EHR)

Responses

Status	Meaning
200	User deleted
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	User or organisation not found

A successful response (200) returns no response body.

Patients

Patients are linked to organisations via a **connection** resource. Patient list, update, connection, permissions, and access-token operations for an organisation require the organisation contract to be signed (403 **OrganisationContractNotSigned** otherwise).

ORB registers a couple of statuses and some flags for each patient, to be able to provide relevant information about the patient connection process to the external client:

- **ConnectionStatus**: Describes the process of requesting NHS registration of the patient from the external organisation. The valid values are:
  - **InviteNotSent**: Invitation for the patient to log in using NHS credentials is not sent yet. Valid only if the patient has never logged in using NHS.
  - **InviteSent**: Invitation for the patient to log in with their NHS credentials has been sent. Valid only if the patient has never logged in with the NHS.
  - **InviteExpired**: Invitation for the patient to log in with their NHS credentials has been sent but expired. Valid only if the patient has never logged in with the NHS.
  - **DataMismatch**: Patient tried to log in with their NHS credentials, but there was a mismatch between the data they have in ORB and the data they have in NHS. If this status is set, two response fields indicate which values differed.
    - **DobMismatch**: This field is true if there is a mismatch in the date of birth.
    - **surnameMismatch**: true if there is a mismatch in the surname. These are boolean fields on the patient/connection response, not errorCode values. Request-body conflicts on Connect/Update use PatientDetailsMismatch (409) instead. While in DataMismatch, Connect Patient by Email / by Link returns the current status only (422) unless resend is true, which sends a new NHS invitation email or returns a new invitation link, subject to the invitation rate limit. The status stays **DataMismatch** until the patient completes NHS login.
  - **Connected**: Patient did a valid NHS registration, and there are no mismatches. This only indicates patient has NHS login and there is an external patient linked to it. It has nothing to do with permissions to access patient NHS data.
  - **Declined**: The patient used the decline link from the NHS invitation email or Connect-by-Link decline URL (before completing NHS registration). Get Patient Connection Status / List Patients then return connectionStatus **Declined**. Calling Connect again can send a new invitation (no resend flag required). Distinct from **DataMismatch**.

- **DataAccessStatus**: Describes the process of requesting access to the NHS data of the patient from the external organisation. Their valid values are:
- **RequestNotSent**: Request for accessing patient NHS data is not sent yet.
- **RequestSent**: Request for accessing patient NHS data has been sent.
- **Reviewed**: The patient granted the organisation access to his NHS data. This only indicates the patient allowed access to **some** of their NHS data. To know exactly to which data the organisation has access, client must call **Get Granted Permissions** API method. Also, patient data can be blocked from GP side or by the patient. If this status is set, two other fields provide this info.
  - **PatientDataAccessLimited**: This field is true if the patient has restricted access to their data partially or totally (e.g. via passport settings).
  - **GpDataAccessLimited**: This field is true if the GP blocked the patient's data partially or totally in any way. Connect Patient by Email / by Link issues a data-access request email or link only while status is RequestNotSent or RequestSent (not after Reviewed, and not when **connectionStatus is DataMismatch**).

- **Declined**: The patient used the decline link from the data-access request email or Connect-by-Link decline URL. connectionStatus typically remains **Connected**; dataAccessStatus becomes **Declined** and organisation passport grants for that organisation are cleared (patientDataAccessLimited is set to true). Calling Connect again can send a new data-access request (no resend flag required),
  unless connectionStatus is **DataMismatch** or **Declined**. Connect Patient by Email / by Link issues a data-access request email or link while dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined** (not after **Reviewed**, and not when connectionStatus is **DataMismatch** or **Declined**).

Patient decline: Invitation and data-access emails include an ORB-hosted decline link. Connect Patient by Link also returns declineInvitationLink and/or declineDataAccessRequestLink when the corresponding invitation or data-access link is issued. The patient opens that page to decline; the EHR does not call a decline endpoint. The next Get Patient Connection Status (or List Patients) shows Declined as above. This is a 200 status value, not an errorCode.

- **Oldest NHS Record**: The date of the oldest record received from NHS for this patient. If this is relatively recent (e.g. one year ago), it may indicate that the GP has restricted how far back access goes. This is returned as oldestNhsRecordDatein API responses; it may be null if no data has been received yet or cannot be determined.

Data priority and overwrite rules (ORB vs EHR data)

A patient may have data from NHS, from ORB (entered by other organisations), and from the EHR/organisation via the API (name, surname, DOB, postcode, etc.). ORB applies the following rules:

- **NHS data** has the highest priority and is always considered most valid.
- **Connect Patient by Email / by Link** does **not** overwrite demographics on an existing patient:
    - **New patient** (email not already in ORB): ORB creates the patient record from the request body.
    - **Existing patient** (email match): ORB **validates** dateOfBirth and lastName against the stored record. If either differs, the request fails with **409** and errorCode **PatientDetailsMismatch**. Other supplied fields (title, firstName, sex, emailAddress, postcode) are **not** applied on Connect — use Update Patient to change demographics.
- This Connect validation (ORB vs request body) is distinct from the **NHS→ORB mismatch** (when the patient has tried NHS login and ORB data did not match NHS), which is reported as **422** with a response body containing connectionStatus **DataMismatch** and the boolean fields dobMismatch / surnameMismatch (see Connect Patient by Email / by Link and Get Patient Connection Status).
- **NHS Login when the NHS number is already linked:** Connect still matches existing ORB patients by **email only**. A new email creates a **new** ORB patient even if the person is the same. Each NHS number can be linked to **only one** ORB patient. If the patient later completes NHS Login on that second invite and the NHS number is already linked to another ORB patient:
    - ORB compares the NHS surname and date of birth with the **existing NHS-linked patient** (not the second invite record).
    - If either does not match: no new NHS Login is created. This organisation's connection is set to **DataMismatch** (dobMismatch / surnameMismatch) and the patient UI shows the data-mismatch dialog — same as a normal mismatch. Correct demographics with Update Patient and resend with resend: true.
    - If both match: ORB treats the second record as a duplicate. The existing patient's NHS Login and NHS number are kept. This organisation's connection is re-linked to that patient (extPatientId unchanged). Organisation membership is moved if not already present (no duplicate membership). The connection becomes **Connected** and mismatch flags are cleared. The duplicate patient and their login are then deleted. No new NHS Login is created for the duplicate.
    - From the EHR, the API contract does not change: the same extPatientId still identifies the connection; Get Patient Connection Status / List Patients return **Connected**. Demographics on those responses are those of the retained NHS-linked patient. Connect does **not** return an errorCode for this. Resolution happens only at NHS Login — Connect does not match on NHS number.
- **Update Patient** applies its own overwrite rules (see that endpoint): without NHS Login, supplied demographics overwrite ORB data; with NHS Login, firstName / lastName / dateOfBirth must be included and match the NHS-controlled values (omit → **409** PatientDetailsMismatch).

Example: if the EHR supplies a postcode and NHS has not provided one, the EHR postcode overwrites any existing ORB postcode for that patient.

ORB uses the following process when a connection request is made, updating patient statuses each time:

1. First, it checks if the patient already exists in the system, using the email as key. ORB does not support two patients with the same email address; there is at most one patient per email.
    - If the patient does not exist, ORB creates the patient record and the external link record for this organisation, then continues.
    - If the patient exists (email match), it checks if the date of birth and surname sent in the request match the ones of the existing patient (see Data priority above).
    - If they don't match, an error is returned to the EHR and the request fails (409). Surname and DOB are not overwritten in this case.
    - If they match, the existing patient record is left unchanged — other request fields are not applied on Connect.
    - Patient connection status is changed to **InviteNotSent**.

2. Then, it checks if the patient has NHS login.

- If not, sends an ORB NHS registration email to the user, and waits for the user to click the link and sign up using NHS Login.
- If the email has been sent before (patient is in InviteSent status), and it has not expired yet, a resend flag must be included in the body of the request to indicate that client wants to resend the email anyway. The same applies while the patient is in DataMismatch: after correcting the patient details with Update Patient, call Connect with resend: true to send a new invitation. The status remains DataMismatch until NHS login succeeds.
- This email can be sent at most twice per 24 hours, to avoid spamming the patient with too many of these emails.
- Patient connection status is changed to InviteSent.

3. When the patient tries to log in using NHS, ORB compares the surname and DOB held in ORB with the NHS details.

- If they don't match: the NHS login is not created and the ORB patient record is left unchanged. Every **external link** for this patient is set to **DataMismatch**, recording which field(s) failed (dobMismatch, surnameMismatch). The EHR corrects the patient details with Update Patient and then calls Connect with resend: true so the patient can retry NHS login.
- If the NHS number is already linked to a different ORB patient, ORB compares NHS surname and DOB with **that** patient. A mismatch sets **DataMismatch** on this organisation's connection. A match re-links this organisation's extPatientId to the existing NHS-linked patient, sets **Connected**, and deletes the duplicate ORB patient (see Data priority above). No new NHS Login is created for the duplicate.
- When the patient later completes NHS login with matching details, every external link for that patient becomes **Connected**.
- If they match, patient connection status is set to **Connected** (step 4).

4. If there are no mismatches, patient connection status is changed to **Connected**.

5. Then, it asks the patient to grant NHS access permissions to the requesting Org.

- An email is sent for this, which redirects to patient passport access page after login. After this, patient data access request status is changed to **RequestSent**.
- A data-access request email or link is issued while dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined** (and connectionStatus is not **DataMismatch** or **Declined**). Calling Connect again while **RequestSent** or **Declined** can send (or return a link for) another request **without** requiring resend: true. Sending remains subject only to the data-access request rate limit (see **Rate limits** below). The resend flag applies only to **NHS invitation** emails/links while connectionStatus is **InviteSent or DataMismatch** (step 2).
- Once the patient has reviewed access (dataAccessStatus is **Reviewed**), Connect does **not** send or return a further data-access request.
- If patient allows any access to their data, patient data access request status is changed to Reviewed.

Note that patient can allow data access partially, and their data can still be blocked from GP.

Rate limits (emails and links)

ORB may apply a rate limit to patient connection emails and links. When a rate limit is in force, ORB uses one maximum value, counted separately for:

- **NHS invitation** emails or links; and
- **Data-access request emails** or links.

The limit is evaluated **per patient, per organisation, over a rolling 24-hour period**.
If the relevant limit has been reached, Connect Patient by Email / by Link does not send a new email or return a new link and responds with **429** and **errorCode ResendLimitExceeded**. If no limit is in force, these calls are not rejected for rate limiting.
Invitation resend still requires **resend: true** while an NHS invitation is pending **(connectionStatus InviteSent) or while connectionStatus is DataMismatch)**; rate limits apply in addition to that rule. Data-access request reminders **do not use** the resend flag — only the data-access rate limit applies.

Link validity and renewal

The two links returned or sent by the connection endpoints have different validity rules:

Link type	Used when	Validity
NHS registration / invitation link	The patient has not completed NHS registration	Expires after a system-configurable period (7 days by default), counted from when the link is generated. Email and direct-link flows use the same type of token. After expiry, connectionStatus becomes InviteExpired.
Data-access / consent link	The patient has completed NHS registration and needs to review access for the organisation	Does not use a timed invitation token and therefore does not expire after a fixed number of days. The URL opens the ORB login page; the patient must sign in before they can review access.

Only one current NHS registration token is retained for a patient. When ORB generates a new registration link, the previous registration link is invalidated immediately and the configured expiry period starts again. To request a replacement while an invitation is still pending, set resend to true. Generation and sending remain subject to the NHS invitation rate limit above.

The data-access / consent URL is not a time-limited invitation token, so requesting it again does not "renew" an expiry window. Reissuing it does not require **resend: true**; it is subject only to the data-access request rate limit above.

Guidance for EHR implementers (data access)

Use the following when building your integration:

- **If access has not yet been reviewed** (dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined**): You can call Connect Patient by Email or Connect Patient by Link again for a data-access reminder while rate limits allow (see **Rate limits** above); ORB will send (or return a link for) a reminder when permitted. Connect does **not** issue a data-access request when connectionStatus is **DataMismatch** or **Declined**. If connectionStatus is **Declined**, call Connect again to send a new NHS invitation instead.
- **If the patient has granted access** (dataAccessStatus is **Reviewed**): Connect does **not** send or return another data-access request. Check the detailed return values and call **Get Granted Permissions** for the data sets granted. If something you need is missing, ask the patient to grant more through your own messaging or patient-facing flows outside Connect — calling Connect again will not trigger a further access request.
- **If oldestNhsRecordDate is not very old** (e.g. only one or two years back): Consider informing the patient that they may need to ask their GP to allow access to older records, or use in-app messaging to suggest they check GP restrictions.
- **If patientDataAccessLimited is true**: The patient has restricted what data is shared. Consider informing the clinician and the patient may need to grant more access via their passport settings.
- **If gpDataAccessLimited is true**: Warn the clinician. They should check whether the data available is sufficient; if not, they can ask the patient to request that the GP provide more access.
- **If the granted permissions (Get Granted Permissions) do not include what you need**: Tell the clinician which data sets (e.g. allergies, medications) the patient has not granted. Allow the clinician to ask the patient to grant more through your own messaging — Connect will not re-request access after **Reviewed**.

List Patients

GET /organisations/{extOrganisationId}/patients

Returns a list of patients for the specified organisation. Pagination is optional - if no pagination parameters are provided, all patients are returned as an array. If pagination parameters are provided, a paginated response with metadata is returned.

Path Parameters

Name	Description
extOrganisationId	External Organisation ID (EHR)

Query Parameters

Name	Type	Required	Default	Description
limit	integer	No	-	Maximum number of patients to return (1-1000). If omitted, all patients are returned
offset	integer	No	0	Number of patients to skip before returning results. Only used when limit is provided
connectionStatus	string	No	-	Filter by connection status (InviteNotSent, InviteSent, InviteExpired, DataMismatch, Connected, Declined)
dataAccessStatus	string	No	-	Filter by data access request status (RequestNotSent, RequestSent, Reviewed, Declined)
patientDataAccessLimited	boolean	No	-	When true, filter to patients which have restricted their data (patient-side)
gpDataAccessLimited	boolean	No	-	When true, filter to patients which have their data blocked from GP side
dobMismatch	boolean	No	-	When true, filter to patients whose date of birth in ORB mismatches the one in NHS
surnameMismatch	boolean	No	-	When true, filter to patients whose surname in ORB mismatches the one in NHS
nhsNumber	string	No	-	Filter by NHS number from NHS Login in ORB (digits only; spaces/hyphens allowed in the query value)

Response Body (No Pagination)

When no pagination parameters are provided, the response is a simple array:


```
[
  {
    "extPatientId": "string",
    "title": "string",

    "firstName": "string",
    "lastName": "string",
    "dateOfBirth": "string",
    "sex": "string",
    "emailAddress": "string",
    "postcode": "string",
    "connectionStatus": "string",
    "dobMismatch": boolean,
    "surnameMismatch": boolean,
    "patientDataAccessLimited": boolean,
    "gpDataAccessLimited": boolean,
    "dataAccessStatus": "string",
    "nhsNumber": "string",
     "oldestNhsRecordDate": "string",
    "lastInvitationEmailDate": "string",
    "lastAccessRequestEmailDate": "string"
  }
]
```

Response Body (With Pagination)

When a limitis provided, the response includes pagination metadata:


```
{
  "patients": [
    {
      "extPatientId": "string",
      "title": "string",
      "firstName": "string",
      "lastName": "string",
      "dateOfBirth": "string",
      "sex": "string",
      "emailAddress": "string",
      "postcode": "string",
      "connectionStatus": "string",
      "dobMismatch": boolean,
      "surnameMismatch": boolean,
      "patientDataAccessLimited": boolean,
      "gpDataAccessLimited": boolean,
      "dataAccessStatus": "string",
      "nhsNumber": "string",
       "oldestNhsRecordDate": "string",
      "lastInvitationEmailDate": "string",
      "lastAccessRequestEmailDate": "string"
    }
  ],
  "pagination": {
    "total": 150,
    "limit": 100,
    "offset": 0,
    "hasMore": true
  }
}
```

Response Body Fields

When pagination is not used (array response):

Field	Type	Description
[].extPatientId	string	External patient ID (EHR)
[].title	string	Patient title
[].firstName	string	Patient's first name
[].lastName	string	Patient's last name
[].dateOfBirth	string	Date of birth in YYYY-MM-DD format
[].sex	string	Patient sex (Male, Female, NotApplicable)
[].emailAddress	string	Patient email address
[].postcode	string	Patient postcode
[].connectionStatus	string	Connection status (InviteNotSent, InviteSent, InviteExpired, DataMismatch, Connected, Declined)
[].dobMismatch	boolean	When connectionStatus is DataMismatch: true if date of birth mismatch detected (optional)
[].surnameMismatch	boolean	When connectionStatus is DataMismatch: true if surname mismatch detected (optional)
[].patientDataAccessLimited	boolean	When applicable: true if the patient has restricted their data partially or totally (optional)
[].gpDataAccessLimited	boolean	When applicable: true if the GP has blocked the patient's data partially or totally (optional)
[].dataAccessStatus	string	Data access request status (RequestNotSent, RequestSent, Reviewed, Declined) (optional)
[].nhsNumber	string	NHS number from NHS Login in ORB (read-only; optional; omitted or null if not on record)
[].oldestNhsRecordDate	string	Date of oldest NHS record received (ISO-8601); null if none or not determined (optional)
[].lastInvitationEmailDate	string	ISO-8601 date of the last NHS registration invitation email sent (optional)
[].lastAccessRequestEmailDate	string	ISO-8601 date of the last data access request email sent (optional)

When pagination is used (object response):

Field	Type	Description
patients	array	Array of patient objects
patients[].extPatientId	string	External patient ID (EHR)
patients[].title	string	Patient title
patients[].firstName	string	Patient's first name
patients[].lastName	string	Patient's last name
patients[].dateOfBirth	string	Date of birth in YYYY-MM-DD format
patients[].sex	string	Patient sex (Male, Female, NotApplicable)
patients[].emailAddress	string	Patient email address
patients[].postcode	string	Patient postcode
patients[].connectionStatus	string	Connection status (InviteNotSent, InviteSent, InviteExpired, DataMismatch, Connected, Declined)
patients[].dobMismatch	boolean	When connectionStatus is DataMismatch: true if date of birth mismatch detected (optional)
patients[].surnameMismatch	boolean	When connectionStatus is DataMismatch: true if surname mismatch detected (optional)
patients[].patientDataAccessLimited	boolean	When applicable: true if the patient has restricted their data partially or totally (optional)
patients[].gpDataAccessLimited	boolean	When applicable: true if the GP has blocked the patient's data partially or totally (optional)
patients[].dataAccessStatus	string	Data access request status (RequestNotSent, RequestSent, Reviewed, Declined) (optional)
patients[].nhsNumber	string	NHS number from NHS Login in ORB (read-only; optional; omitted or null if not on record)
patients[].oldestNhsRecordDate	string	Date of oldest NHS record received (ISO-8601); null if none or not determined (optional)
patients[].lastInvitationEmailDate	string	ISO-8601 date of the last NHS registration invitation email sent (optional)
patients[].lastAccessRequestEmailDate	string	ISO-8601 date of the last data access request email sent (optional)
pagination	object	Pagination metadata
pagination.total	integer	Total number of patients in the organisation
pagination.limit	integer	Number of patients requested per page
pagination.offset	integer	Number of patients skipped
pagination.hasMore	boolean	Whether there are more patients available

Example Requests (combine filters as needed using AND)

Get all patients (no pagination):

```
GET /organisations/ORG123/patients
```

Get only connected patients:

```
GET /organisations/ORG123/patients?connectionStatus=Connected
```

Get connected patients with patient-restricted data access:

```
GET
/organisations/ORG123/patients?connectionStatus=Connected&patientDataAccessLimited=true
```

Get connected patients with blocked GP data access:

```
GET
/organisations/ORG123/patients?connectionStatus=Connected&gpDataAccessLimited=true
```

Get connected patients with patient-granted access:

```
GET
/organisations/ORG123/patients?connectionStatus=Connected&dataAccessStatus=Reviewed
```

Get patients with date of birth mismatch:

```
GET /organisations/ORG123/patients?connectionStatus=DataMismatch&dobMismatch=true
```

Get patient by NHS number:

```
GET /organisations/ORG123/patients?nhsNumber=9434765919
```

Get patients with surname mismatch:

```
GET
/organisations/ORG123/patients?connectionStatus=DataMismatch&surnameMismatch=true
```

Get first 100 patients (with pagination):

```
GET /organisations/ORG123/patients?limit=100&offset=0
```

Get next 50 patients:

```
GET /organisations/ORG123/patients?limit=50&offset=100
```

Responses

Status	**Meaning**
200	OK
400	Invalid pagination parameters (limit > 1000, limit < 1, or offset < 0), or invalid filter value for connectionStatus, dataAccessStatus, patientDataAccessLimited, gpDataAccessLimited, dobMismatch, surnameMismatch, or nhsNumber
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Organisation not found

Update Patient

PATCH /organisations/{extOrganisationId}/patients/{extPatientId}

Updates one or more demographic attributes of an existing patient within an organisation. This is typically used when the EHR updates patient details such as contact information or postcode.

Behaviour depends on whether the patient has completed NHS Login:

- **No NHS Login** — supplied firstName, lastName, and dateOfBirth overwrite the values stored in ORB. Other supplied fields (title, sex, emailAddress, postcode) also overwrite ORB data. Omitted fields are left unchanged.
- **NHS Login present** — firstName, lastName, and dateOfBirth are controlled by NHS-verified data and are not overwritten. ORB compares these three fields on the request to the values on record. A mismatch (including when any of them is **omitted**) returns **409** PatientDetailsMismatch. To update other fields (title, sex, emailAddress, postcode), include firstName, lastName, and dateOfBirth with values that match the current NHS-controlled record.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

```
{
  "title": "string",
  "firstName": "string",
  "lastName": "string",
  "dateOfBirth": "string",
  "sex": "string",
  "emailAddress": "string",
  "postcode": "string"
}
```

Request Body

Request Body Fields

Field	Type	Required	Description
title	string	No	Patient title (Mr, Mrs, Miss, Ms, Dr, Other)
firstName	string	No	Patient's first name
lastName	string	No	Patient's last name (surname)
dateOfBirth	string	No	Date of birth in YYYY-MM-DD format
sex	string	No	Patient sex (Male, Female, NotApplicable)
emailAddress	string	No	Patient email address
postcode	string?	No	Patient postcode. Send null to clear; omit to leave unchanged. An empty or whitespace-only string is stored as sent. Maximum length 15.

When updating an existing patient:

- **Without NHS Login**: supplied firstName, lastName, and dateOfBirth overwrite ORB data. Other supplied fields overwrite ORB data as usual. Omitted fields are unchanged.
- **With NHS Login**: include matching firstName, lastName, and dateOfBirth (omitting any of them is treated as a mismatch and returns 409 PatientDetailsMismatch). Those three fields are not overwritten. Other supplied fields (title, sex, emailAddress, postcode) may still be updated.
- **Clearing** postcode**:** omit the field to leave the stored value unchanged; send null to clear it. Any other value is stored as sent, including an empty or whitespace-only string.

Response Body (200)

On success, ORB returns the patient's **current demographic fields** as stored after the update (not an empty body). Values may differ from the request where NHS Login blocked changes to **name/DOB**, or where only some fields were supplied..

```
{
  "title": "Ms",
  "sex": "Male",
  "dateOfBirth": "1933-11-14",
  "firstName": "Simon",
  "lastName": "OLLEY",
  "postcode": "asdas123",
  "emailAddress": "patient@example.com"
}
```


Response Body Fields (200)

Field	Type	Description
title	string	Patient title (Mr, Mrs, Miss, Ms, Dr, Other; may be null)
sex	string	Patient sex (Male, Female, NotApplicable; may be null)
dateOfBirth	string	Date of birth in YYYY-MM-DD format
firstName	string	Patient's first name
lastName	string	Patient's last name (surname)
postcode	string	Patient postcode (may be null if not set)
emailAddress	string	Patient email address (may be null in ORB if not set)

This response does **not** include extPatientId, connectionStatus, or other list-only fields (see **List Patients**).

Responses

Status	Meaning
200	Patient updated; response body is current demographics (see above)
400	Update failed due to invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Patient or organisation not found
409	Conflict — patient has NHS Login and request firstName / lastName / dateOfBirth do not match the record, including when any of those fields is omitted (PatientDetailsMismatch)
500	Unexpected server error

Connect Patient by Email

POST /organisations/{extOrganisationId}/patients/{extPatientId}/connection-email

Sends an email inviting a patient to sign up and grant permission for the organisation to view NHS records.

- If the patient does not exist, ORB creates a new patient record and sends a NHS invitation email.
- If the patient exists but is not connected, ORB sends the invitation email directly (unless resend=false and an invitation is already pending). In this case, ORB validates that date of birth and surname in the request match the existing ORB patient record (matched by email). A mismatch returns **409** (PatientDetailsMismatch). Other request fields are not applied on Connect — use **Update Patient** to change demographics.
- If the patient is already connected, ORB may send a data-access request email only while dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined** (and not when connectionStatus is **DataMismatch** or **Declined**), subject to the data-access rate limit. After **Reviewed**, no further data-access request email is sent. Invitation and data-access emails include an ORB-hosted decline link; if the patient uses it, Get Patient Connection Status returns **Declined** (see Patients statuses above).

The EHR may call this endpoint again to send a **reminder** (e.g. if the patient has not yet completed NHS login, declined the invitation, or while dataAccessStatus is still **RequestNotSent** / **RequestSent** / **Declined**). Whether an email is sent is subject to the rate limits in the Patients section above: an NHS invitation can be resent when resend is true (while **InviteSent**), or without resend when connectionStatus is **Declined**; a data-access request email can be sent again only while status is **RequestNotSent**, **RequestSent**, or **Declined** and the data-access rate limit allows — resend is not required for data-access reminders.

This includes the ID of the requesting Clinician User, so ORB can include this in the email.

The invitation opens ORB's patient-facing NHS linking page. Logo and welcome text for that page are configured via Set Organisation Branding.

The NHS registration link in the email expires after the configured invitation period (**7 days by default**). Sending a replacement registration email generates a new link, invalidates the previous link, and restarts the expiry period. A data-access / consent email uses a login URL without a separate link expiry.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Request Body

```
{
  "title": "string",
  "firstName": "string",
  "lastName": "string",
  "dateOfBirth": "string",
  "sex": "string",
  "emailAddress": "string",
  "postcode": "string",
  "requestingClinicianId": "string",
  "resend": boolean
}
```

Request Body Fields

Field	Type	Required	Description
title	string	Yes	Patient title (Mr, Mrs, Miss, Ms, Dr, Other)
firstName	string	Yes	Patient's first name
lastName	string	Yes	Patient's last name
dateOfBirth	string	Yes	Date of birth in YYYY-MM-DD format
sex	string	Yes	Patient sex (Male, Female, NotApplicable)
emailAddress	string	Yes	Patient email address
postcode	string	No	Patient postcode. May be omitted, null or empty. If provided, maximum length 15.
requestingClinicianId	string	Yes	External user ID of the requesting clinician.
resend	boolean	No	true to force resend of an **NHS invitation** email while connectionStatus is **InviteSent or DataMismatch**. Not used for data-access request reminders.

Responses

Status	Meaning
200	Invite path — connectionStatus is InviteSent (invitation email sent, or already invited and invite flow still applies). Also returned when resend: true sends a new invitation while connectionStatus is DataMismatch; the status stays DataMismatch.
201	Patient is Connected (NHS registration complete; a data-access request email may be sent when applicable)
400	Connection failed due to invalid request or validation error
403	Organisation contract not signed (**OrganisationContractNotSigned**), or EHR API disabled (**ApiDisabled**)
404	Organisation or requesting clinician not found
409	Conflict — external patient ID already in use, or DOB/surname does not match existing ORB patient (PatientDetailsMismatch). Same as Connect by Link. Distinct from 422.
422	Returned when the patient's connection status is **DataMismatch** (NHS login revealed a mismatch between ORB and NHS data) and no new invitation was issued (resend not true). Response body includes connectionStatus **DataMismatch** with dobMismatch/surnameMismatch. Distinct from 409 (request body does not match ORB, or external patient ID already in use).
429	Rate limit exceeded — the maximum number of connection emails allowed per patient per organisation in 24 hours has been reached (**ResendLimitExceeded)**

Note: InviteSent status codes differ (email **200**, link **201**). Both return **409** PatientDetailsMismatch when email exists with non-matching DOB/surname.

Response Body (200 / 201)

On success, the response body returns the current connection and data access status:

```
{
  "connectionStatus": "string",
  "dobMismatch": false,
  "surnameMismatch": false,
  "patientDataAccessLimited": false,
  "gpDataAccessLimited": false,
  "dataAccessStatus": "string",
  "oldestNhsRecordDate": "string",
  "lastInvitationEmailDate": "string",
  "lastAccessRequestEmailDate": "string"
}
```

Response Body Fields (200 / 201)

Field	Type	Description
connectionStatus	string	Connection status (InviteNotSent, InviteSent, InviteExpired, DataMismatch, Connected, Declined)

Response Body Fields (200 / 201)

Field	Type	Description
dobMismatch	boolean	When connectionStatus is DataMismatch: true if date of birth mismatch detected (optional)
surnameMismatch	boolean	When connectionStatus is DataMismatch: true if surname mismatch detected (optional)
patientDataAccessLimited	boolean	When applicable: true if the patient has restricted their data partially or totally (optional)
gpDataAccessLimited	boolean	When applicable: true if the GP has blocked the patient's data partially or totally (optional)
dataAccessStatus	string	Data access request status (RequestNotSent, RequestSent, Reviewed, Declined) (optional)
oldestNhsRecordDate	string	Date of oldest NHS record received (ISO-8601); null if none or not determined (optional)
lastInvitationEmailDate	string	ISO-8601 date of the last NHS registration invitation email sent (optional)
lastAccessRequestEmailDate	string	ISO-8601 date of the last data access request email sent (optional)

Error Response Body (422)

When a validation error occurs (422 status), the response body looks the same as the success response, with connectionStatus**DataMismatch** and dobMismatch/ surnameMismatchindicating which validation failed:

```
{
  "connectionStatus": "DataMismatch",
  "dobMismatch": true,
  "surnameMismatch": false,
  "patientDataAccessLimited": false,
  "gpDataAccessLimited": false,
  "dataAccessStatus": "string",
  "oldestNhsRecordDate": "string",
  "lastInvitationEmailDate": "string",
  "lastAccessRequestEmailDate": "string"
}
```

Error Response Body Fields (422)

Field	Type	Description
connectionStatus	string	DataMismatch (validation error)
dobMismatch	boolean	true if date of birth mismatch detected
surnameMismatch	boolean	true if surname mismatch detected
patientDataAccessLimited	boolean	Optional; when applicable, true if patient has restricted their data
gpDataAccessLimited	boolean	Optional; when applicable, true if GP has blocked patient data
dataAccessStatus	string	Optional; RequestNotSent, RequestSent, Reviewed, or Declined
oldestNhsRecordDate	string	Optional; ISO-8601 date
lastInvitationEmailDate	string	Optional; ISO-8601 date
lastAccessRequestEmailDate	string	Optional; ISO-8601 date

In case of any other error (for example **409** PatientDetailsMismatch, **429** ResendLimitExceeded, **404**), the response body uses the compact Common Errors shape with **both** errorCode and errorMessage present. Use errorCode for programmatic handling; errorMessage is for display only.

Connect Patient by Link

POST /organisations/{extOrganisationId}/patients/{extPatientId}/connection-link

Returns an invitation link, which can be sent to a patient as part of a link request.

- If the patient does not exist, ORB creates a new patient record, a NHS invitation link is built and returned (**201**, connectionStatus **InviteSent**).
- If the patient exists but is not connected, a NHS invitation link is built and returned (**201**, connectionStatus **InviteSent**) when an invitation is issued. In this case, ORB validates that date of birth and surname in the request match the existing ORB patient record (matched by email). A mismatch returns **409** (PatientDetailsMismatch) — same as Connect by Email. Other request fields are not applied on Connect — use Update Patient to change demographics.
- If the patient is already connected, it is indicated with response code **201** and no link for NHS invitation is returned.

In all previous cases, a data-access request link is built and returned only while dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined** (and connectionStatus is not **DataMismatch** or **Declined**), subject to the data-access rate limit. After **Reviewed**, no data-access request link is returned. When an invitation or data-access link is issued, the response also includes the matching decline URL (declineInvitationLink / declineDataAccessRequestLink) for the EHR to pass to the patient if needed.

Calling this endpoint again allows the EHR to obtain a fresh link to send as a **reminder** to the patient. An NHS invitation link is returned again only when resend is true while **InviteSent** (and the invitation rate limit allows), or without resend when connectionStatus is **Declined**. A data-access request link can be returned again only while dataAccessStatus is **RequestNotSent**, **RequestSent**, or **Declined** and the data-access rate limit allows — resend is not required for data-access reminders. Exceeding a limit returns **429** (ResendLimitExceeded).

The returned invitation link opens ORB's patient-facing NHS linking page. Logo and welcome text for that page are configured via Set Organisation Branding.

An NHS registration link expires after the configured invitation period (**7 days by default**). Generating a replacement invalidates the previous registration link and restarts the expiry period. A returned data-access / consent link opens the ORB login page and does **not** expire after a fixed number of days (it is not a timed invitation token); the patient must sign in before reviewing access.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Request Body

```
{
  "title": "string",
  "firstName": "string",
  "lastName": "string",
  "dateOfBirth": "string",
  "sex": "string",
  "emailAddress": "string",
  "postcode": "string",
  "requestingClinicianId": "string",
  "resend": boolean
}
```

Request Body Fields

Field	Type	Required	Description
title	string	Yes	Patient title (Mr, Mrs, Miss, Ms, Dr, Other)
firstName	string	Yes	Patient's first name
lastName	string	Yes	Patient's last name
dateOfBirth	string	Yes	Date of birth in YYYY-MM-DD format
sex	string	Yes	Patient sex (Male, Female, NotApplicable)
emailAddress	string	Yes	Patient email address
postcode	string	No	Patient postcode. May be omitted, null or empty. If provided, maximum length 15.
requestingClinicianId	string	Yes	External user ID of the requesting clinician
resend	boolean	No	true to force a new **NHS invitation** link while connectionStatus is **InviteSent**. Not used for data-access request links.

Response Body


```
{
  "invitationLink": "string",
  "declineInvitationLink": "string",
  "dataAccessRequestLink": "string",
  "declineDataAccessRequestLink":"string",
  "connectionStatus": "string",
  "dobMismatch": false,
  "surnameMismatch": false,
  "patientDataAccessLimited": false,
  "gpDataAccessLimited": false,
  "dataAccessStatus": "string",
  "oldestNhsRecordDate": "string",
  "lastInvitationEmailDate": "string",
  "lastAccessRequestEmailDate": "string"
}
```

Response Body Fields

Field	Type	Description
invitationLink	string	URL to the patient invitation that can be shared or displayed
declineInvitationLink	string	ORB-hosted decline URL for the NHS invitation; present when invitationLink is returned. If the patient opens it, connectionStatus becomes **Declined**.
dataAccessRequestLink	string	URL for the patient to grant data access to the organisation
declineDataAccessRequestLink	string	ORB-hosted decline URL for the data-access request; present when dataAccessRequestLink is returned. If the patient opens it, dataAccessStatus becomes **Declined**.
connectionStatus	string	Connection status (InviteNotSent, InviteSent, InviteExpired, DataMismatch, Connected)
dobMismatch	boolean	When connectionStatus is DataMismatch: true if date of birth mismatch detected (optional)
surnameMismatch	boolean	When connectionStatus is DataMismatch: true if surname mismatch detected (optional)
patientDataAccessLimited	boolean	When applicable: true if the patient has restricted their data partially or totally (optional)
gpDataAccessLimited	boolean	When applicable: true if the GP has blocked the patient's data partially or totally (optional)
dataAccessStatus	string	Data access request status (RequestNotSent, RequestSent, Reviewed, Declined) (optional)
oldestNhsRecordDate	string	Date of oldest NHS record received (ISO-8601); null if none or not determined (optional)
lastInvitationEmailDate	string	ISO-8601 date of the last NHS registration invitation email sent (optional)
lastAccessRequestEmailDate	string	ISO-8601 date of the last data access request email sent (optional)

Responses

Status	Meaning
201	Typical success — connectionStatus is **InviteSent** or **Connected**. When an NHS invitation link is issued (new/expired invite, Declined re-invite, or resend: true), ORB returns **201** and advances status to **InviteSent**, except from **DataMismatch**, which is kept until NHS login succeeds. Treat **201** as the invitation success path (same body shape as below).
200	Mapped only if connectionStatus were still InviteNotSent or InviteExpired. After a normal successful Link call that issues an invitation, status is already InviteSent, so partners should not rely on 200 for invite success.
400	Connection failed due to invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Organisation or requesting clinician not found
409	Conflict — external patient ID already in use, or DOB/surname does not match existing ORB patient (PatientDetailsMismatch). Same as Connect by Email. Distinct from 422.
422	Returned when the patient's connection status is **DataMismatch** (NHS login revealed a mismatch between ORB and NHS data) and no new invitation was issued (resend not true). Response body includes connectionStatus **DataMismatch** with dobMismatch/surnameMismatch. Distinct from 409 (request body does not match ORB, or external patient ID already in use).
429	Rate limit exceeded — the maximum number of connection links allowed per patient per organisation in 24 hours has been reached (**ResendLimitExceeded**)

Error Response Body (422)

When a validation error occurs (422 status), the response body looks the same as the success response, with connectionStatus**DataMismatch** and dobMismatch/ surnameMismatchindicating which validation failed:


```
{
  "invitationLink": "string",
  "dataAccessRequestLink": "string",
  "connectionStatus": "DataMismatch",
  "dobMismatch": true,
  "surnameMismatch": false,
  "patientDataAccessLimited": false,
  "gpDataAccessLimited": false,
  "dataAccessStatus": "string",
  "oldestNhsRecordDate": "string",
  "lastInvitationEmailDate": "string",
  "lastAccessRequestEmailDate": "string"
}
```


Error Response Body Fields (422)

Field	Type	Description
invitationLink	string	May be null or empty
dataAccessRequestLink	string	May be null or empty
connectionStatus	string	DataMismatch (validation error)
dobMismatch	boolean	true if date of birth mismatch detected
surnameMismatch	boolean	true if surname mismatch detected
patientDataAccessLimited	boolean	Optional; when applicable, true if patient has restricted their data
gpDataAccessLimited	boolean	Optional; when applicable, true if GP has blocked patient data
dataAccessStatus	string	Optional; RequestNotSent, RequestSent, Reviewed, or Declined
oldestNhsRecordDate	string	Optional; ISO-8601 date
lastInvitationEmailDate	string	Optional; ISO-8601 date
lastAccessRequestEmailDate	string	Optional; ISO-8601 date

In case of any other error (for example **409** PatientDetailsMismatch, **429** ResendLimitExceeded, **404**), the response body uses the compact Common Errors shape with **both** errorCode and errorMessage present. Use errorCode for programmatic handling; errorMessage is for display only..

Get Patient Connection Status

GET /organisations/{extOrganisationId}/patients/{extPatientId}/connection

Returns the connection status and access levels for the patient. The response body uses the shape below.

The response may include **nhsNumber**: the NHS number stored on the patient's NHS Login record in ORB after NHS Login verification. This field is read-only for the EHR — it is not supplied on Connect or Update. **nhsNumber** is omitted or null when the patient has no NHS Login on record. The same read-only field (and an optional **nhsNumber** query filter) is also available on List Patients.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Response Body

```
{
  "connectionStatus": "string",
  "dobMismatch": boolean,
  "surnameMismatch": boolean,
  "patientDataAccessLimited": boolean,
  "gpDataAccessLimited": boolean,
  "dataAccessStatus": "string",
  "nhsNumber": "string"
  "oldestNhsRecordDate": "string",
  "lastInvitationEmailDate": "string",
  "lastAccessRequestEmailDate": "string"
}
```

When connectionStatusis **DataMismatch**, dobMismatchand surnameMismatchindicate which validation failed.

Response Body Fields

Field	Type	Description
connectionStatus	string	Connection status (see Possible Status Values below)
dobMismatch	boolean	When connectionStatus is DataMismatch: true if date of birth mismatch detected (optional)
surnameMismatch	boolean	When connectionStatus is DataMismatch: true if surname mismatch detected (optional)
patientDataAccessLimited	boolean	When applicable: true if the patient has restricted their data partially or totally (optional)
gpDataAccessLimited	boolean	When applicable: true if the GP has blocked the patient's data partially or totally (optional)
dataAccessStatus	string	Data access request status (RequestNotSent, RequestSent, Reviewed, Declined) (optional)
nhsNumber	string	NHS number from the patient's NHS Login record after NHS Login verification (read-only; optional; omitted or null if no NHS Login on record)
oldestNhsRecordDate	string	Date of oldest NHS record received (ISO-8601); null if none or not determined (optional)
lastInvitationEmailDate	string	ISO-8601 date of the last NHS registration invitation email sent (optional)
lastAccessRequestEmailDate	string	ISO-8601 date of the last data access request email sent (optional)

Possible Status Values (connectionStatus)

Status	Description
InviteNotSent	Invitation for the patient to log in using NHS credentials is not sent yet
InviteSent	Invite has been sent to the patient
InviteExpired	Invitation has been sent but expired
DataMismatch	Validation error (date of birth and/or surname mismatch); see dobMismatch and surnameMismatch
Connected	Patient is connected to the organisation
Declined	Patient declined the NHS invitation via the decline link (before NHS registration). Distinct from dataAccessStatus **Declined**.

Responses

Status	Meaning
200	OK
400	Bad request
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Patient or organisation not found

Get Granted Permissions

GET /organisations/{extOrganisationId}/patients/{extPatientId}/permissions

Returns the list of data permissions that the patient has granted to this organisation. This endpoint requires that the patient is connected to the organisation (see Get Patient Connection Status).

Connection Status Requirements:

- If the patient connection status is Connected, this endpoint returns the granted permissions (HTTP **200**).
- If the connection status is **any other value** (InviteNotSent, InviteSent, InviteExpired, DataMismatch, or Declined), this endpoint returns HTTP **404** with errorCode **PatientInvalidStatus**. Permissions are only available after NHS connection is established (Connected).

This can be used by the EHR to determine what data will be available before requesting an access token, or to display permission status to clinicians.

Note: Issuing an access token checks that the patient is Connected. Limited patient or GP data access (patientDataAccessLimited / gpDataAccessLimited) does not block token issue. Individual dataset grants (for example Allergies or Documents) are enforced inside the widget when NHS record data is fetched; restricted data types show a limited-data message instead of records. This permissions endpoint is informational for the EHR.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Response Body

```
[
  "Allergies",
  "Medication History",
  "Immunisations",
  "Problems",
  "Documents",
  "Consultation History",
  "TestResults"
]
```

Response Body Fields

Field	Type	Description
[ ]	array of string	Array of permission names granted to the patient

Possible Permission Values

- Allergies
- Medication History
- Immunisations
- Problems
- TestResults
- Documents
- Consultation History

Responses

Status	Meaning
200	OK - Returns array of permissions
400	Bad request
403	Access denied — NonClinicianAccess (isClinician: false); OrgIsSuspended; PatientInvalidStatus (patient not Connected); OrganisationContractNotSigned; NhsModuleDisabled; or ApiDisabled / ApiKeyExpired
404	Patient or organisation not found, or patient is not Connected (PatientInvalidStatus — includes InviteNotSent, InviteSent, InviteExpired, DataMismatch, Declined)

Remove Patient Connection

DELETE /organisations/{extOrganisationId}/patients/{extPatientId}/connection

Removes the link between the patient and the organisation. Use this when a patient leaves a clinic; doing so is treated as an implied retraction of the organisation's permission to view that patient's records. Whether to call this API is for the EHR or organisation to decide.

Behaviour: This is an unlink only for the organisation in the request:

- The EHR connection for this organisation is removed, so the patient no longer appears in List Patients for that organisation, and token/connection/status/permissions calls for this patient and organisation fail.
- The patient-to-organisation link for that organisation is also removed, so the patient can no longer access that organisation.
- The underlying patient account, PatientLogin, and NHS data are retained. Other organisation links for the same patient are untouched.
- If the patient still has one or more other organisations, they can continue to log in and use those organisations.
- If this was the patient's last organisation, they cannot log in until they are linked to at least one organisation again. The patient account and any completed NHS registration are kept (not deleted).
- If the same patient is connected again later, ORB treats them as an existing patient (matched by email, with DOB/surname validation). Because NHS login already exists, re-connect returns a data-access / data-share link rather than a new NHS invitation link.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Responses

Status	Meaning
200	Connection removed
400	Deletion failed due to invalid request or validation error
403	Organisation contract not signed (OrganisationContractNotSigned), or EHR API disabled (ApiDisabled)
404	Patient or organisation not found
500	Unexpected server error

A successful response (200) returns no response body.

Patient Access

The Patient Access API enables secure viewing of NHS patient records within an EHR system via an embedded iFrame widget. Issuing a patient access token requires the organisation contract to be signed (”403” **OrganisationContractNotSigned** otherwise). The security model ensures that:

1. **Server-side token generation**: Tokens are only issued to authenticated EHR backend systems, never directly to browsers
2. **User identification**: Each token request identifies the specific clinician requesting access
3. **Authorisation checks**: ORB validates that the user, organisation, and patient relationships are valid and authorised
4. **Short-lived tokens**: Tokens expire in 15 minutes to limit exposure
5. **Scoped access**: Tokens are bound to specific user-patient-organisation combinations
6. **Audit trail**: All token requests are logged for compliance and security monitoring. Separately, ORB keeps an internal audit of NHS record screens actually viewed (see NHS records viewing audit)

Typical Flow:

1. Clinician clicks "View NHS Records" button in EHR patient record page
2. EHR backend makes server-side API call to request access token (including clinician's extUserId)
3. ORB validates authorisation and returns JWT token
4. EHR backend passes token to frontend JavaScript widget
5. Widget loads in iframe and authenticates using the token
6. If the clinician has not yet accepted Terms and Conditions (T&C) for this organisation, the widget shows the T&C screen; after acceptance, NHS data can be viewed
7. Widget displays patient data. Token expires after 15 minutes, requiring a new access-token request for continued access

Widget Integration:

The ORB widget is a JavaScript component that must be embedded in the EHR's patient record page. Embedding, token handling, and runtime behaviour are documented in the ORB Widget Integration Guide. The token is passed to the widget via postMessage(recommended; see that guide). Do not call /access-token from the browser.

Clinician Terms and Conditions (widget)

Clinician acceptance of the widget Terms and Conditions is required before NHS data is displayed. See [Terms and Conditions].

NHS records viewing audit

When NHS GP records are displayed — in the clinician widget or in the ORB web application — ORB retains a confidential audit of that access. Each entry identifies the viewer, the organisation, the time of access, and the clinical content presented on screen. Document preview and download are treated as access events. Unsuccessful or empty retrievals are recorded for the same purpose. Capture of the audit is independent of the user interface and does not affect screen rendering.

Individual audit records are not available through the External API. "**GET /stats/nhs-records-viewed**" returns aggregated counts of successful clinician widget views only. Requests to investigate a particular access event should be directed to ORB Support.

Important Security Considerations:

- Tokens must never be logged, stored in browser storage, or exposed in URLs visible to users
- The EHR backend should validate that the requesting user has permission to view the patient before requesting a token
- If a token expires while a user is viewing data, the widget will handle re-authentication automatically Suspended
- organisations (and therefore suspended users) cannot request access tokens

Request Access Token

POST /organisations/{extOrganisationId}/patients/{extPatientId}/access-token

Returns a short-lived JWT used to access patient data via the ORB widget (iframe). Authenticated with that Organisation's X-ORG-API-KEY or the GovBody X-API-KEY. The token is tied to the key used to request it (see Authentication).

Security Model:

- The EHR must make this request server-side (never from the browser) when a clinician clicks to view patient data
- The request must include the extUserIdof the clinician requesting access
- ORB validates that:
    - The user exists and belongs to the specified organisation
    - The user has **“isClinician: true”** (non-clinical users cannot request access tokens)
    - The organisation is not suspended
    - The organisation's NHS module is enabled
    - The organisation has access to the patient
    - The patient is **Connected**
    - Organisation/patient data access is not limited (**patientDataAccessLimited** / **gpDataAccessLimited**)
- The returned JWT token is scoped to the specific user, patient, and organisation
- The token has a short expiration time (15 minutes) to limit exposure if intercepted
- The token should be passed to the widget immediately and not stored or logged

Issuing an access token does not mean the clinician has accepted widget T&C, and it does not mean the organisation’s NHS module is enabled. Token issuance only establishes that the EHR backend is allowed to open the widget for that user, patient, and organisation. T&C and the NHS-module unavailable screen are enforced when the widget loads **— see Terms and Conditions and Organisation NHS module.**

Requesting an access token is recorded as clinician access to that patient for the organisation. ORB uses this (together with patient access) for data access review and retention policies.

Path Parameters

Name	Description
extOrganisationId	External organisation ID (EHR)
extPatientId	External patient ID (EHR)

Request Body

```
{
  "extUserId": "string"
}
```

Request Body Fields

Field	Type	Required	Description
extUserId	string	Yes	External user ID (EHR) of the requesting user

Response Body

```
{
  "accessToken": "string",
  "expiresIn": 900
}
```

Response Body Fields

Field	Type	Description
accessToken	string	Short-lived JWT token for accessing patient data (expires in expiresIn seconds)
expiresIn	number	Token expiration time in seconds (typically 900 = 15 minutes)

JWT Token Claims

The JWT token contains the following claims:

- clientScopeId - Internal API-key client identifier
- extOrganisationId- The organisation ID
- extUserId- The clinician user ID who requested access
- extPatientId- The patient ID
- iat- Issued at timestamp
- exp- Expiration timestamp
- aud- Audience (e.g., "orb-widget")
- iss- Issuer (e.g., "orb-api")

Responses

Status	Meaning
200	Token issued successfully
400	Invalid request (missing extUserId)
403	Access denied — NonClinicianAccess (isClinician: false); OrgIsSuspended; PatientInvalidStatus (patient not Connected); **OrganisationContractNotSigned; NhsModuleDisabled; or ApiDisabled / ApiKeyExpired**
404	Patient, user, or organisation not found
500	Internal server error (see Common Errors)

Stats

Analytics endpoints for the Governing Body linked to the API key. Results include **only organisations for that Governing Body** (not other EHRs). Optional extOrganizationKey limits the response to one organisation; omit it to return a row per organisation.

When extOrganizationKey is supplied, these endpoints return only that Organisation's figures and accept either that Organisation's X-ORG-API-KEY or its GovBody's X-API-KEY (when X-ORG-API-KEY is sent it is the key that is checked). Without extOrganizationKey they are authenticated with the GovBody X-API-KEY and return figures for every Organisation in the GovBody. They are **not** gated by organisation-contract signing (OrganisationContractNotSigned is not returned). SQL reporting views used inside ORB are **not** part of this External API.

The API returns **counts**, not percentages. The EHR computes rates (granted / declined / no-response) from those counts.

Practice-level uptake for the two-step patient funnel:

Step	What was sent	Outcome fields
NHS invitation	Connect by Email or Connect by Link	connected / declined invitation / no response
Data-access request	Request for the organisation to see NHS datasets	granted / declined data access / no response

Declined is distinct from **not granted yet**. Invitation decline is connectionStatus = Declined. Data-access decline is dataAccessStatus = Declined. No-response is everything still outstanding (including InviteExpired and DataMismatch on the invitation side).

Date range

All four consent endpoints accept optional fromDate / toDate (ISO-8601). Invalid range (fromDate after toDate) returns **400**.

Filter	How counts are produced
Omitted	Current snapshot: patients who have ever been sent an invitation and/or a data-access request
Supplied	Distinct patients with at least one sent invitation or data-access link in that window. Outcome fields use the patient's current status, not the status at send time

Counts are **distinct patients**, not the number of emails or link generations. Both Connect by Email and Connect by Link count as a send.

Query Parameters (all four consent endpoints)

Name	Type	Required	Description
extOrganizationKey	string	No	EHR organisation ID (same value as extOrganisationId on other endpoints). Omit to return all organisations in the GovBody (requires the GovBody X-API-KEY); when supplied, the request may use that Organisation's X-ORG-API-KEY or the GovBody X-API-KEY.
fromDate	string (ISO-8601)	No	Include sends at or after this time
toDate	string (ISO-8601)	No	Include sends at or before this time

Common responses (all four)

Status	Meaning
200	OK
400	Bad request (including fromDate after toDate)
401	Missing API key (see Common Errors)
403	X-ORG-API-KEY sent and it is invalid, belongs to another organisation, expired or disabled (OrgApiKeyInvalid / OrgApiKeyExpired / OrgApiDisabled)
404	GovBody X-API-KEY is unknown (ClientNotFound), or extOrganizationKey is not an organisation in the GovBody (OrgNotFound)

Get Links Sent Stats

GET /stats/links-sent

How many distinct patients were sent an NHS invitation and how many were sent a data-access request, per organisation.

Response Body (200)

```
[
  {
    "organizationName": "string",
    "extOrganisationKey": "string",
    "invitationsSent": 0,
    "dataAccessRequestsSent": 0
  }
]
```

Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
invitationsSent	integer	Distinct patients sent an NHS invitation
dataAccessRequestsSent	integer	Distinct patients sent a data-access request

---

Get Consent Granted Stats

GET /stats/consent-granted

Among patients sent a data-access request, how many currently have **at least one** NHS dataset granted to the organisation.

This is dataset access (passport flags), not organisation-contract signing and not clinician widget T&C.

Response Body (200)


```
[
  {
    "organizationName": "string",
    "extOrganisationKey": "string",
    "dataAccessRequestsSent": 0,
    "consentGranted": 0
  }
]
```


Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
dataAccessRequestsSent	integer	Distinct patients sent a data-access request
consentGranted	integer	Of those, patients with at least one NHS dataset enabled for the organisation

---

Get Consent Declined Stats

GET /stats/consent-declined

Patients who used the ORB decline page: NHS invitation decline and data-access decline are counted separately.

Response Body (200)


```
[
  {
    "organizationName": "string",
    "extOrganisationKey": "string",
    "invitationsSent": 0,
    "declinedInvitations": 0,
    "dataAccessRequestsSent": 0,
    "dataAccessRequestsDeclined": 0
  }
]
```

Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
invitationsSent	integer	Distinct patients sent an NHS invitation
declinedInvitations	integer	Of those, connectionStatus = Declined
dataAccessRequestsSent	integer	Distinct patients sent a data-access request
dataAccessRequestsDeclined	integer	Of those, dataAccessStatus = Declined

---

Get No-Response Stats

GET /stats/no-response

Patients who were sent an invitation or data-access request and have neither completed nor declined.

Response Body (200)


```
[
  {
    "organizationName": "string",
    "extOrganisationKey": "string",
    "invitationsSent": 0,
    "noResponseInvitations": 0,
    "dataAccessRequestsSent": 0,
    "noResponseDataAccessRequests": 0
  }
]
```


Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
invitationsSent	integer	Distinct patients sent an NHS invitation
noResponseInvitations	integer	Of those, not Connected and not Declined (includes InviteSent, InviteExpired, DataMismatch)
dataAccessRequestsSent	integer	Distinct patients sent a data-access request
noResponseDataAccessRequests	integer	Of those, not dataAccessStatus = Declined and no NHS dataset enabled for the organisation

Get Widget Terms Stats

GET /stats/widget-terms

Returns a **current snapshot** of clinician widget Terms & Conditions acceptance per organisation (not the organisation contract). There is **no date-range filter**.

- Archived EHR users (isArchived) are **excluded**.
- Counts are widget T&C only. There is no separate “declined T&C” flag: **not signed** includes users who have never opened the widget.
- isClinician and isLocum are **independent**. A locum clinician (isClinician: true and isLocum: true) is counted in **both** the clinician split and the locum split, as well as in the overall signed / not-signed totals.

Query Parameters

Name	Type	Required	Description
extOrganizationKey	string	No	EHR organisation ID (same value as extOrganisationId on other endpoints). Omit to return all organisations in the GovBody (requires the GovBody X-API-KEY); when supplied, the request may use that Organisation's X-ORG-API-KEY or the GovBody X-API-KEY.

Response Body (200)
Array of organisations:

```
{

"organizationName":"string",
"extOrganisationKey":"string",
"signed": 0,
"notSigned": 0,
"clinicianSigned": 0,
"clinicianNotSigned":0,
"locumSigned": 0,
"locumNotSigned": 0

 }
```

Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
signed	integer	Non-archived users who have accepted widget T&C
notSigned	integer	Non-archived users who have not accepted widget T&C
clinicianSigned	integer	Non-archived users with isClinician: true who have accepted
clinicianNotSigned	integer	Non-archived users with isClinician: true who have not accepted
locumSigned	integer	Non-archived users with isLocum: true who have accepted
locumNotSigned	integer	Non-archived users with isLocum: true who have not accepted

Responses

Status	Meaning
200	OK
400	Bad request
401	Missing API key (see Common Errors)
403	X-ORG-API-KEY sent and it is invalid, belongs to another organisation, expired or disabled (OrgApiKeyInvalid / OrgApiKeyExpired / OrgApiDisabled)
404	GovBody X-API-KEY is unknown (ClientNotFound), or extOrganizationKey is not an organisation in the GovBody (OrgNotFound)

Get NHS Records Viewed Stats

GET /stats/nhs-records-viewed

Returns how many **distinct patients** had NHS records viewed in the clinician widget, per organisation and per user.

Counting rules:

- Source: successful clinician views of a patient's NHS records in the clinician widget (from ORB's internal NHS records viewing audit; failed loads are not counted).
- Only **non-archived** EHR users (widget users) are included.
- Organisation patientsViewed is the number of **distinct patients** viewed at that practice. It is **not** the sum of users[].patientsViewed. If two clinicians view the same patient, that patient counts once at organisation level and once on each of those users.
- Every non-archived user is listed, including those with patientsViewed: 0.
- There is **no** page-level breakdown.

Optional fromDate / toDate filter the audits by visit time (inclusive). Invalid range (fromDate after toDate) returns **400**.

Query Parameters

Name	Type	Required	Description
extOrganizationKey	string	No	EHR organisation ID (same value as extOrganisationId on other endpoints). Omit to return all organisations in the GovBody (requires the GovBody X-API-KEY); when supplied, the request may use that Organisation's X-ORG-API-KEY or the GovBody X-API-KEY.
fromDate	string (ISO-8601)	No	Include visits at or after this time
toDate	string (ISO-8601)	No	Include visits at or before this time

Response Body (200)


```
[
  {
    "organizationName": "string",
    "extOrganisationKey": "string",
    "patientsViewed": 0,
    "users": [
      {
        "extUserId": "string",
        "userName": "string",
        "isClinician": true,
        "isLocum": false,
        "patientsViewed": 0
      }
    ]
  }
]
```

Response Body Fields

Field	Type	Description
organizationName	string	Organisation name in ORB
extOrganisationKey	string	EHR organisation ID
patientsViewed	integer	Distinct patients viewed at this organisation (in the date range, if supplied)
users	array	Non-archived EHR users for the organisation
users[].extUserId	string	EHR user ID
users[].userName	string	User display name
users[].isClinician	boolean	isClinician flag
users[].isLocum	boolean	isLocum flag
users[].patientsViewed	integer	Distinct patients this user viewed at this organisation

Responses

Status	Meaning
200	OK
400	Bad request (including fromDate after toDate)
401	Missing API key (see Common Errors)
403	EHR API disabled (ApiDisabled)
404	Unknown API key (ClientNotFound), or extOrganizationKey is not an organisation for this API key (OrgNotFound)

Terms and Conditions

ORB requires agreement acceptance in more than one place. This section describes those agreements. They are separate processes and must not be confused.

Agreement	Who accepts
Clinician widget T&C	Each clinician user, per organisation
Organisation contract (clinic)	Authorised organisation representative (host-controlled)

Organisation NHS module

If the organisation's **NHS module** is disabled in ORB, the clinician patient-records widget shows an ORB-hosted unavailable / warning screen instead of NHS records. Enabling the module is an ORB organisation administration concern (not an External API setting).

Minting an access token does not fail solely because the NHS module is off. The EHR uses the same embed and token flow; the gate is enforced inside the widget. No separate External API accept/query endpoints exist for this state.
See the **ORB Widget Integration Guide (NHS module gate)**.

Clinician Terms and Conditions (widget)

Before NHS patient data is shown in the embedded widget, each clinician user must accept ORB Clinician Terms and Conditions (T&C) for the organisation they are acting in.
This is the **clinician widget T&C** only (tick-box acceptance inside the same clinician patient-records widget iframe used for NHS data). It is **not** the organisation-level clinic contract, and it does **not** require a separate iframe.

Agreement type and scope

Item	Behaviour
Mechanism	Simplified tick-box (checkbox) acceptance inside the ORB-hosted widget UI
Scope	Acceptance is recorded per clinician user per organisation
Multi-org clinicians	If the same clinician works in multiple organisations in the EHR, they must accept T&C separately for each ORB organisation
T&C content	System-defined wording hosted on ORB as an editable Static Page, so ORB can update the text without an EHR release
Patients	Clinician widget T&C does not apply to patients

Trigger and mandatory acceptance

- The agreement is presented when the clinician first opens / uses the widget for that organisation (after a valid access token has been passed into the iframe).
- Acceptance is mandatory: the clinician cannot reject the terms and continue. NHS record data and related widget data APIs remain blocked until acceptance is completed.
- Re-acceptance: once accepted for a given user–organisation pair, the clinician is **not** required to re-accept T&Cs for the same organisation.

What ORB records

On acceptance, ORB records that the clinician approved the T&Cs for that user–organisation pair (including when it was accepted), for audit and compliance. Until acceptance is completed, the widget shows the T&C screen and widget data requests return `403` with "errorCode" **TermsNotAccepted**.

Hosting and context

- The clinician T&C screen is shown **inside the same clinician patient-records widget iframe** already used for the NHS data view (the host does not implement a separate T&C iframe or External API accept/query endpoints).
- T&C wording is **hosted by ORB** and rendered in that iframe.
- Clinician and organisation context for acceptance comes from the **patient access token** already passed into the widget (scoped user, organisation, patient).
- A PDF of the current T&C wording can be downloaded from within the widget session.

Enforcement vs access token

Step	Clinician T&C status
EHR calls POST .../access-token	Clinician T&C not checked (organisation contract is required — see Organisation contract)
Widget loads and clinician uses medical-record views	Clinician T&C enforced; UI shows T&C screen if not yet accepted; data APIs blocked until accept

EHR integrators: No extra integration is required for clinician T&C beyond embedding the existing patient-records widget and passing the access token. Acceptance and enforcement are handled inside that widget. The ORB External API does not expose endpoints to accept clinician T&C or to query acceptance status. See also the ORB Widget Integration Guide.

Organisation contract (clinic)

Each EHR organisation must complete a separate **organisation-level** ORB contract signing flow before clinicians can access patient NHS data and before most External API operations for that organisation are available.

This uses a **different iframe** from the clinician patient-records widget (the widget used for viewing NHS records and clinician T&C). The host embeds the contract signing page separately and obtains a contract access token (not a patient access token).

The signing UI is hosted by ORB. Contract content, signing logic, audit logging, PDF generation, and download links are handled on the ORB side.

The host controls **when** and **for which organisation** the contract iframe is shown, and **which** user sees the launch button.

- The host should show the contract flow only to the intended authorised organisation representative.
- Name and email submitted in the iframe are recorded as supplied (they may be pre-filled via SET_SIGNATORY and edited by the signatory).

Until the organisation contract is signed:

- Clinician access to patient NHS data is blocked (**POST .../access-token and widget patient-data use return 403 OrganisationContractNotSigned**).
- **Most External API operations are blocked** (Users, Patients, branding, update organisation, and related calls). Only organisation create/get/list/delete and the contract-status / contract-access-token helpers below are available for onboarding.

Scope

Item	Behaviour
Scope	Acceptance is recorded per organisation
Multi-org users	If the same person is linked to multiple organisations, each organisation must sign separately
Content	Contract wording is hosted by ORB and shown inside the contract iframe
Re-signing	One signature per organisation; once signed, contract-status reports contractSigned: true. A further accept attempt inside the contract iframe returns **409** (OrganisationContractAlreadySigned)

Host flow (summary)

- Create the organisation (POST /organisations/{extOrganisationId}) if it does not exist yet.
- Optionally poll GET /organisations/{extOrganisationId}/contract-status.
- When ready, call POST /organisations/{extOrganisationId}/contract-access-token to generate a contract iframe token.
- Open the ORB contract page in a **separate** iframe (path /medical-record-embedded/organisation-contract/sign) and pass the token via postMessage SET_TOKEN. Optionally send SET_SIGNATORY with { first_name, last_name, email } to pre-fill the form.
- Signatory reviews the contract, enters full name and email, ticks acceptance, and submits **inside the iframe**. The host does **not** call a separate External API endpoint to record the signature — ORB handles acceptance within the contract iframe.
- On success, the iframe posts CONTRACT_SIGNED with { **signedContractUrl** }, shows confirmation, and a Download Signed Contract button (**opens the signed PDF via a login-free shared link**). A signed PDF is also emailed to the address submitted.
- Host may poll contract-status again or listen for CONTRACT_SIGNED / orb-widget-contract-signed.

After signing

ORB records the signatory name and email, signing time, and a downloadable signed PDF **stored by ORB** (also emailed to the signatory). Download from the confirmation screen uses a login-free link.

Allowed before the contract is signed

Until the contract is signed, these are the only organisation/contract onboarding operations available. All other External API and clinician patient-data access remains blocked (see below).

Method	Path	Notes
POST	/organisations/{extOrganisationId}	Create organisation (onboarding)
GET	/organisations	List organisations
GET	/organisations/{extOrganisationId}	Get organisation
GET	/organisations/{extOrganisationId}/contract-status	Poll signing status
POST	/organisations/{extOrganisationId}/contract-access-token	Generates contract iframe token
DELETE	/organisations/{extOrganisationId}	Delete organisation (allowed before signing so a mistakenly created organisation can be removed)

Blocked until the contract is signed

Until **contractSigned** is true, protected External API and widget operations for that organisation return **403** with errorCode **OrganisationContractNotSigned** (see Common Errors). This includes **all clinician access to patient NHS data** via access token / widget.

Method	Path
PATCH	/organisations/{extOrganisationId}
POST	/organisations/{extOrganisationId}/branding
GET	/organisations/{extOrganisationId}/users
POST	/organisations/{extOrganisationId}/users/{extUserId}
PATCH	/organisations/{extOrganisationId}/users/{extUserId}
DELETE	/organisations/{extOrganisationId}/users/{extUserId}
GET	/organisations/{extOrganisationId}/patients
PATCH	/organisations/{extOrganisationId}/patients/{extPatientId}
POST	/organisations/{extOrganisationId}/patients/{extPatientId}/connection-email
POST	/organisations/{extOrganisationId}/patients/{extPatientId}/connection-link
GET	/organisations/{extOrganisationId}/patients/{extPatientId}/connection
DELETE	/organisations/{extOrganisationId}/patients/{extPatientId}/connection
GET	/organisations/{extOrganisationId}/patients/{extPatientId}/permissions
POST	/organisations/{extOrganisationId}/patients/{extPatientId}/access-token
—	Widget NHS patient-data APIs (after a patient access token is used in the iframe)

There is no separate External API “create patient” endpoint; patient onboarding uses the connection and related patient endpoints above, which are blocked until the contract is signed.

Support and API access

- **API keys and base URLs:** Provided when your integration is onboarded. The GovBody X-API-KEY continues to work as today. Organisation API keys (X-ORG-API-KEY) can be generated after Create Organisation (POST .../api-key) or issued by ORB; contact ORB to regenerate, disable or re-enable. Use the appropriate base URL for your environment (UAT, Test, or Production).
- **Technical support and issues:** For integration support, reporting defects, or questions about this API, contact your ORB integration contact or the support channel provided with your API key.
- **Rate limits**: Patient connection email/link calls may be rate-limited by ORB (**see Rate limits under Patients**). Other throttling, if any, will be communicated with your API key or in separate operational guidance.
